

BÁO CÁO THỰC HÀNH

Thực hành Nhập môn Mạng máy tính Lab 04: Quét lỗ hổng bảo mật với Nessus

GVTH: Nguyễn Ngọc Trưởng

Ngày báo cáo: 05/05/2026

Nhóm 13 – NT101.Q22.1

THÔNG TIN CHUNG

MSSV	Họ và tên	Nội dung báo cáo	% công việc
23520536	Phạm Cao Minh Hoàng	Câu 1,Câu4	50%
24521388	Nguyễn Hoàng Phúc	Câu 2, câu 3	50%

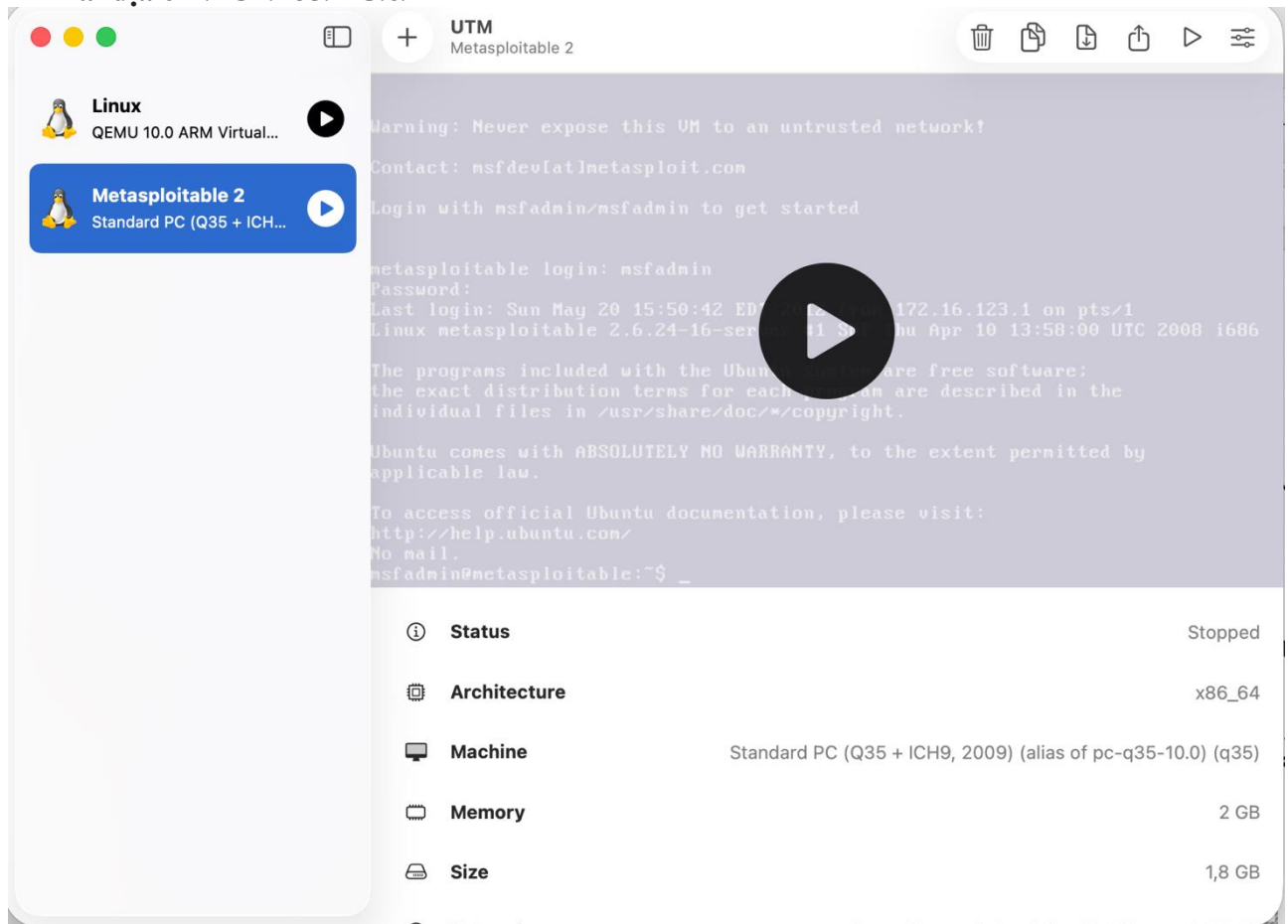
1. PHẦN I: CÁC THỨ CẦN CHUẨN BỊ

1.1. Mục tiêu

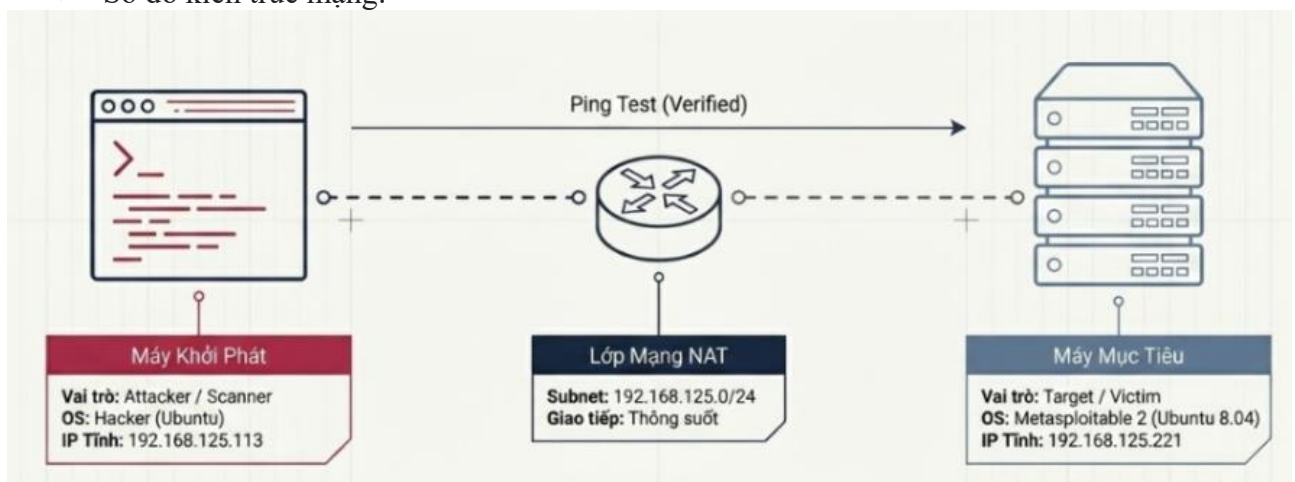
Chuẩn bị môi trường lab gồm hai máy ảo kết nối với nhau qua mạng NAT có địa chỉ 192.168.125.0/24 để thực hiện quét lỗ hổng bằng Nessus.

1.2. Mô hình mạng

- **Phần mềm ảo hóa:** UTM (trên Mac M1 Pro)
- **Mạng:** NAT - Shared Network
- **Dải địa chỉ:** 192.168.125.0/24

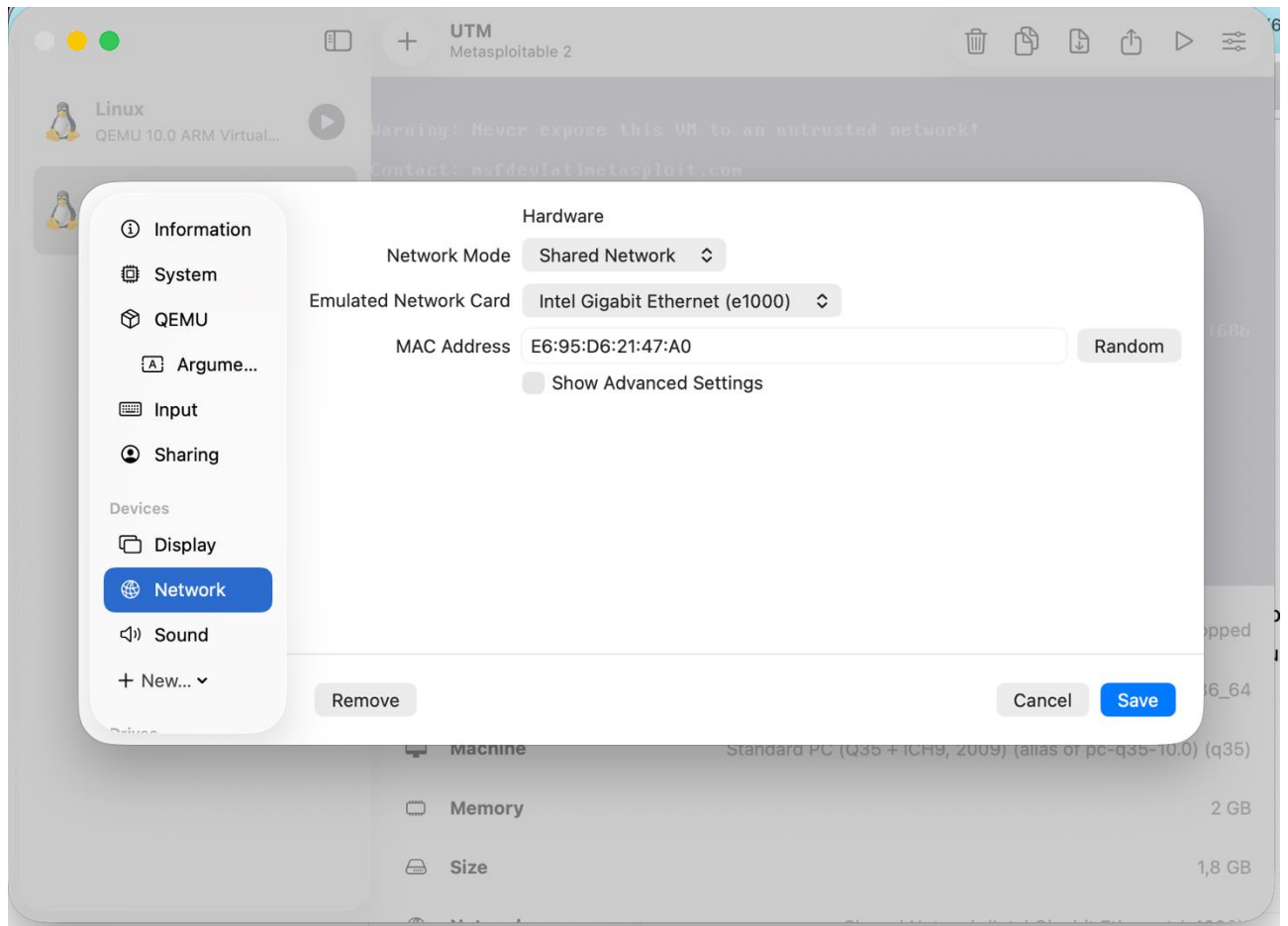


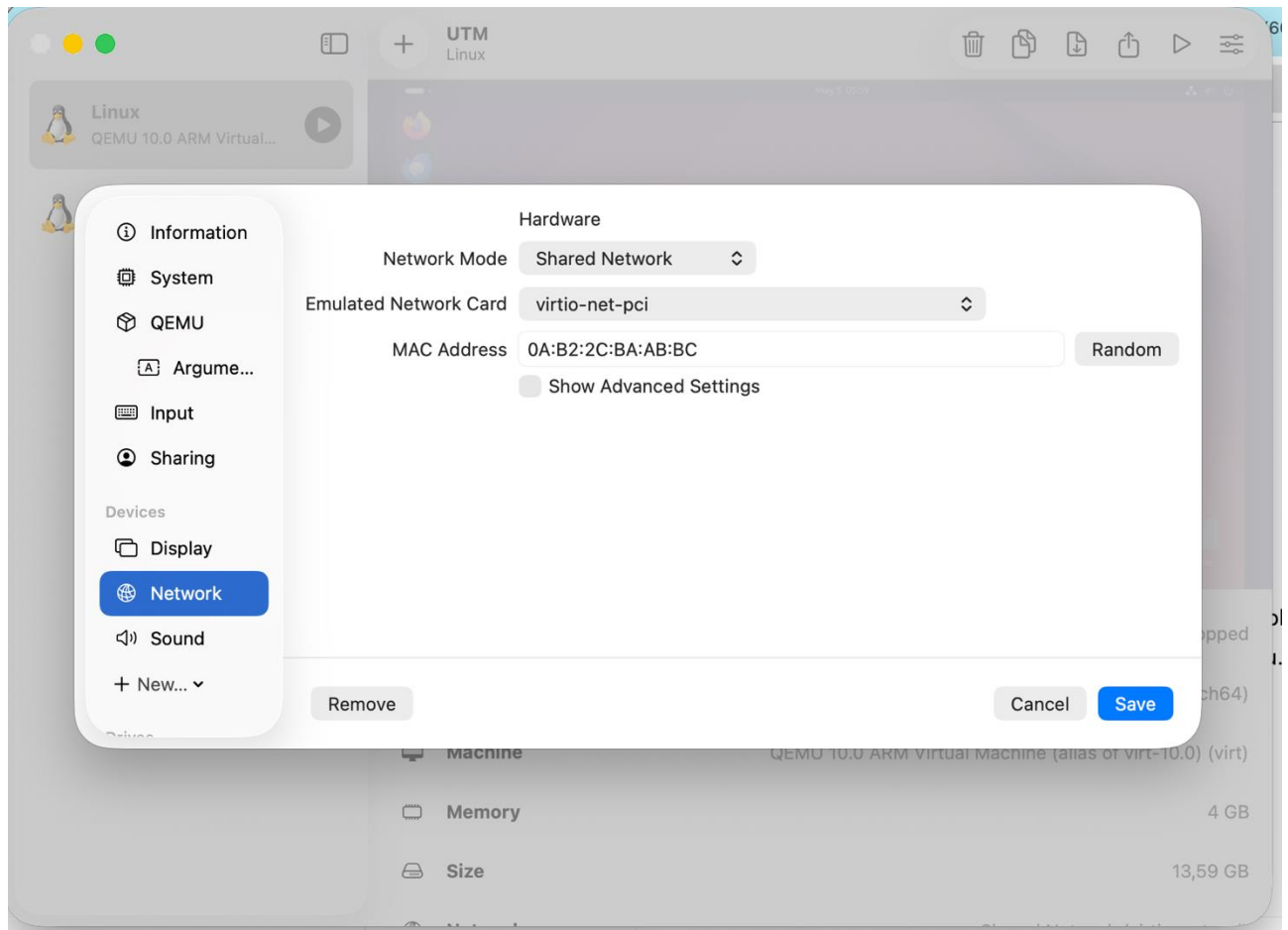
- Sơ đồ kiến trúc mạng:



1.3. Cấu hình Network cho hai máy ảo

Cả hai máy đều được cấu hình sử dụng chung mạng **Shared Network**.





1.4. Đặt địa chỉ IP tĩnh

Bảng tóm tắt địa chỉ IP:

STT	Máy ảo	Địa chỉ IP	Vai trò
1	Hacker (Ubuntu)	192.168.125.113	Máy tấn công
2	Metasploitable 2	192.168.125.221	Máy mục tiêu

Kết quả lệnh ip addr trên máy Metasploitable 2.

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.125.221 netmask 255.0.0.0 up
msfadmin@metasploitable:~$ sudo route add default gw 192.168.125.1
msfadmin@metasploitable:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether e6:95:d6:21:47:a0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.125.221/24 brd 192.168.125.255 scope global eth0
    inet6 fd7b:24bf:cc64:8666:e495:d6ff:fe21:47a0/64 scope global dynamic
        valid_lft 2591957sec preferred_lft 604757sec
    inet6 fe80::e495:d6ff:fe21:47a0/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ _
```

Kết quả lệnh ip addr trên máy Ubuntu Hacker.

```

see the "Default Routes" section of the documentation for more details.
hacker@23520536:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0a:b2:2c:ba:ab:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.125.113/24 brd 192.168.125.255 scope global enp0s1
        valid_lft forever preferred_lft forever
    inet 192.168.64.6/24 metric 100 brd 192.168.64.255 scope global dynamic enp0s1
        valid_lft 3593sec preferred_lft 3593sec
hacker@23520536:~$

```

1.5. Kiểm tra kết nối giữa hai máy

Trên máy Attacker thực hiện lệnh ping đến máy Metasploitable 2.

Kết quả lệnh ping thành công từ máy Attacker sang Metasploitable 2.

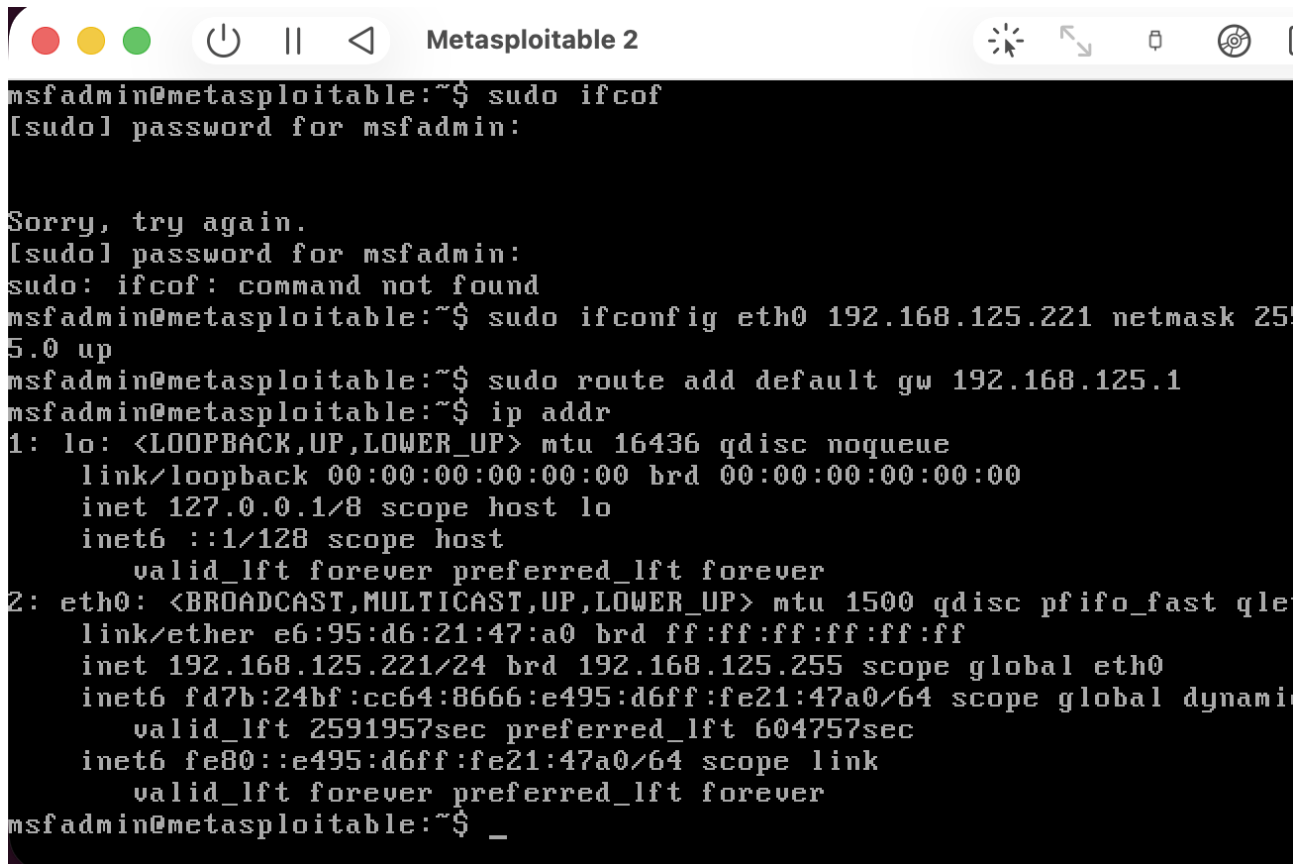
```

hacker@23520536:~$ ping 192.168.125.221 -c 4
PING 192.168.125.221 (192.168.125.221) 56(84) bytes of data.
64 bytes from 192.168.125.221: icmp_seq=1 ttl=64 time=5.94 ms
64 bytes from 192.168.125.221: icmp_seq=2 ttl=64 time=1.63 ms
64 bytes from 192.168.125.221: icmp_seq=3 ttl=64 time=0.924 ms
64 bytes from 192.168.125.221: icmp_seq=4 ttl=64 time=2.21 ms
--- 192.168.125.221 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 0.924/2.676/5.939/1.938 ms
hacker@23520536:~$

```

1.6. Kiểm tra Metasploitable 2

- Đăng nhập thành công với tài khoản mặc định.
- Hệ điều hành: Ubuntu 8.04 (Metasploitable 2.0).



```

msfadmin@metasploitable:~$ sudo ifconfig
[sudo] password for msfadmin:

Sorry, try again.
[sudo] password for msfadmin:
sudo: ifconfig: command not found
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.125.221 netmask 255.255.255.0 up
msfadmin@metasploitable:~$ sudo route add default gw 192.168.125.1
msfadmin@metasploitable:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether e6:95:d6:21:47:a0 brd ff:ff:ff:ff:ff:ff
    inet 192.168.125.221/24 brd 192.168.125.255 scope global eth0
    inet6 fd7b:24bf:cc64:8666:e495:d6ff:fe21:47a0/64 scope global dynamic
        valid_lft 2591957sec preferred_lft 604757sec
    inet6 fe80::e495:d6ff:fe21:47a0/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$ _

```

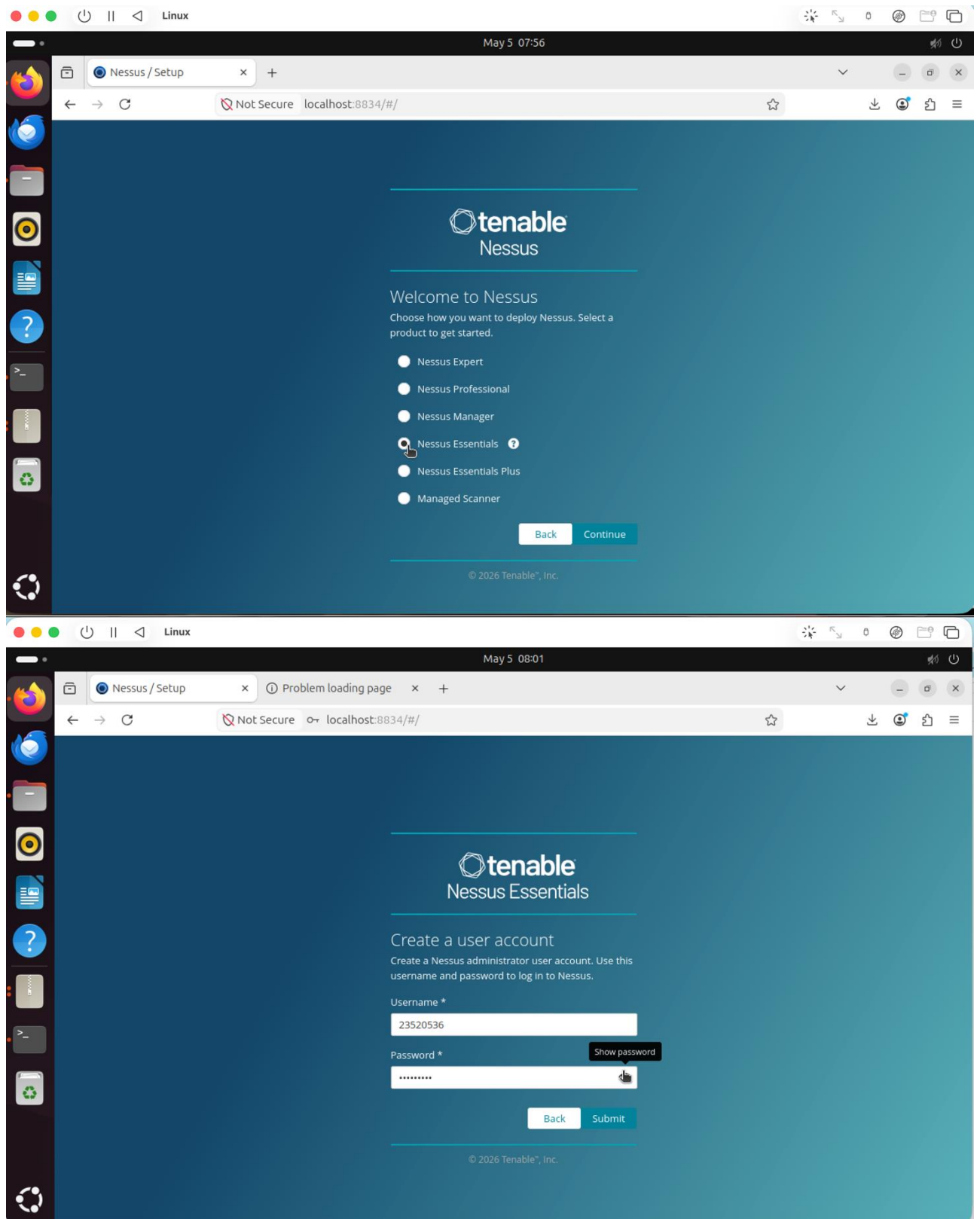
1.7. Chuẩn bị cài Nessus

Máy Attacker đã sẵn sàng để cài đặt Nessus.

```

hacker@23520536:~/Downloads$ cd ~/Downloads
sudo dpkg -i Nessus-*.deb
Selecting previously unselected package nessus.
(Reading database ... 171438 files and directories currently installed.)
Preparing to unpack Nessus-10.12.0-ubuntu1804_aarch64.deb ...
Unpacking nessus (10.12.0) ...
Setting up nessus (10.12.0) ...
HMAC : (KAT_Integrity) : Pass
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RNG : (Continuous_RNG_Test) : Pass
RSA : (KAT_Signature) : Pass
ECDSA : (KAT_Signature) : Pass
ECDSA : (KAT_Signature) : Pass
DSA : (KAT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass

```

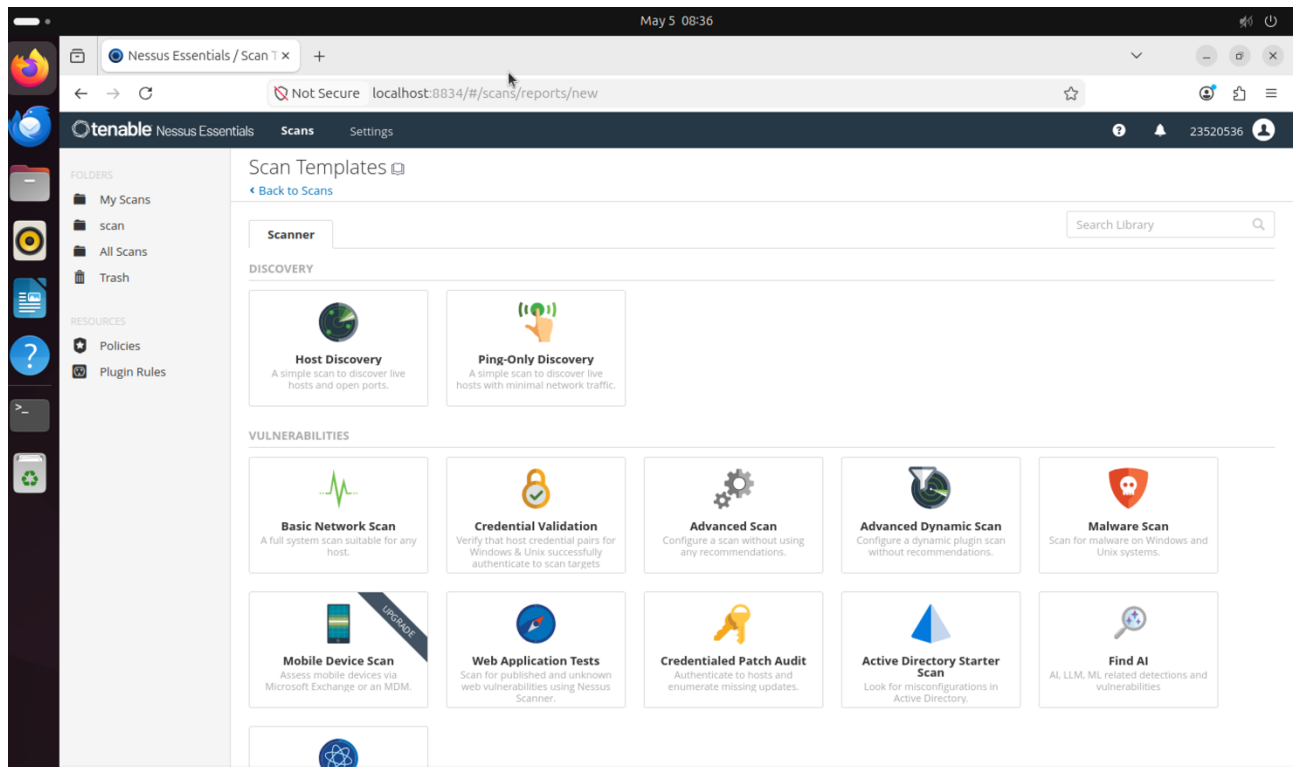


PHẦN II: NỘI DUNG BÀI TẬP

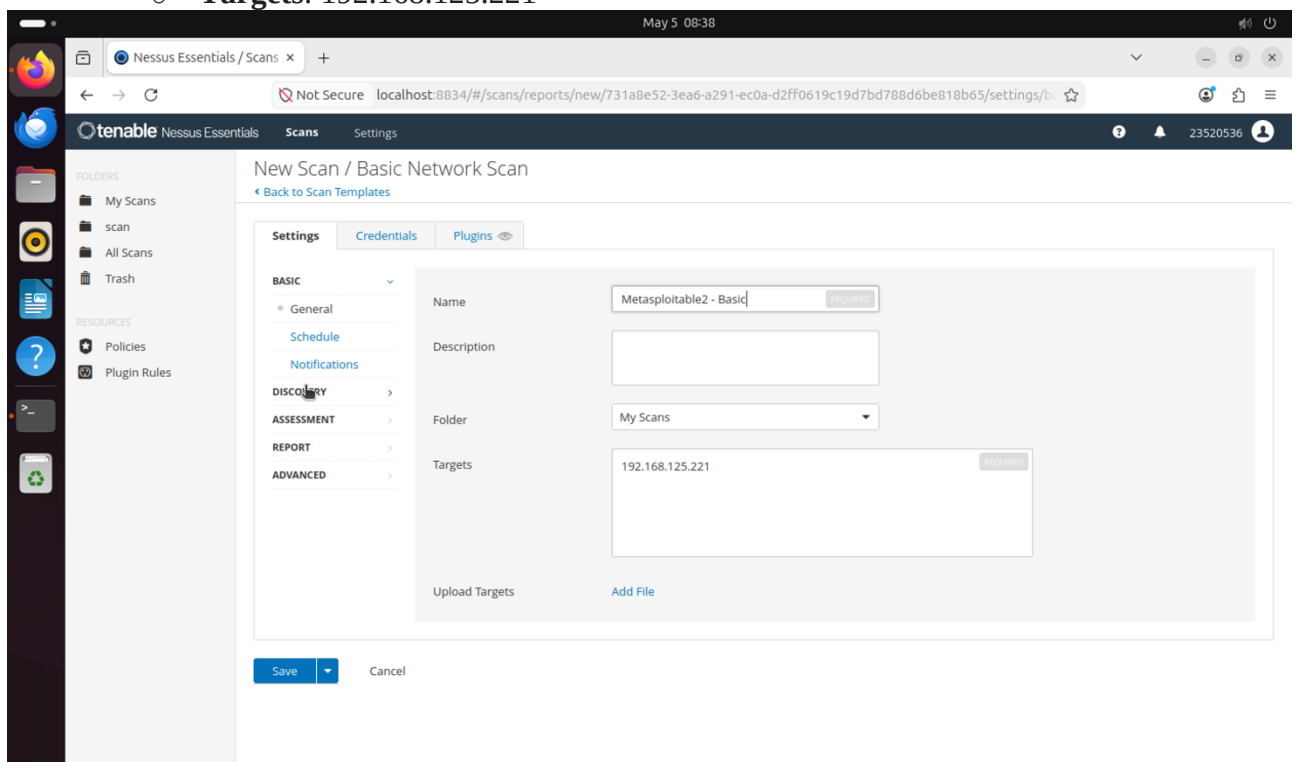
2.1. Nhiệm vụ 2.1 – Quét lỗ hổng không sử dụng tài khoản chứng thực

2.1.1 Các bước thực hiện:

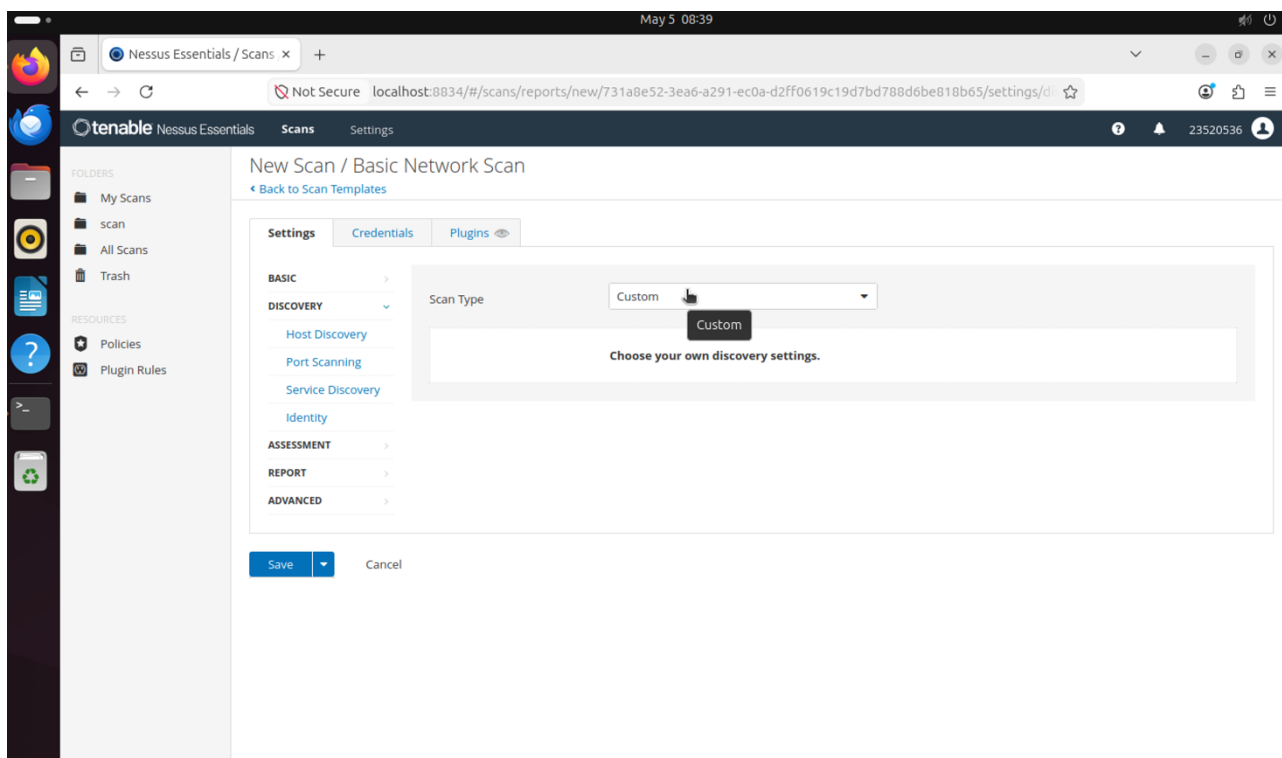
1. Truy cập Nessus → Click **New Scan**.



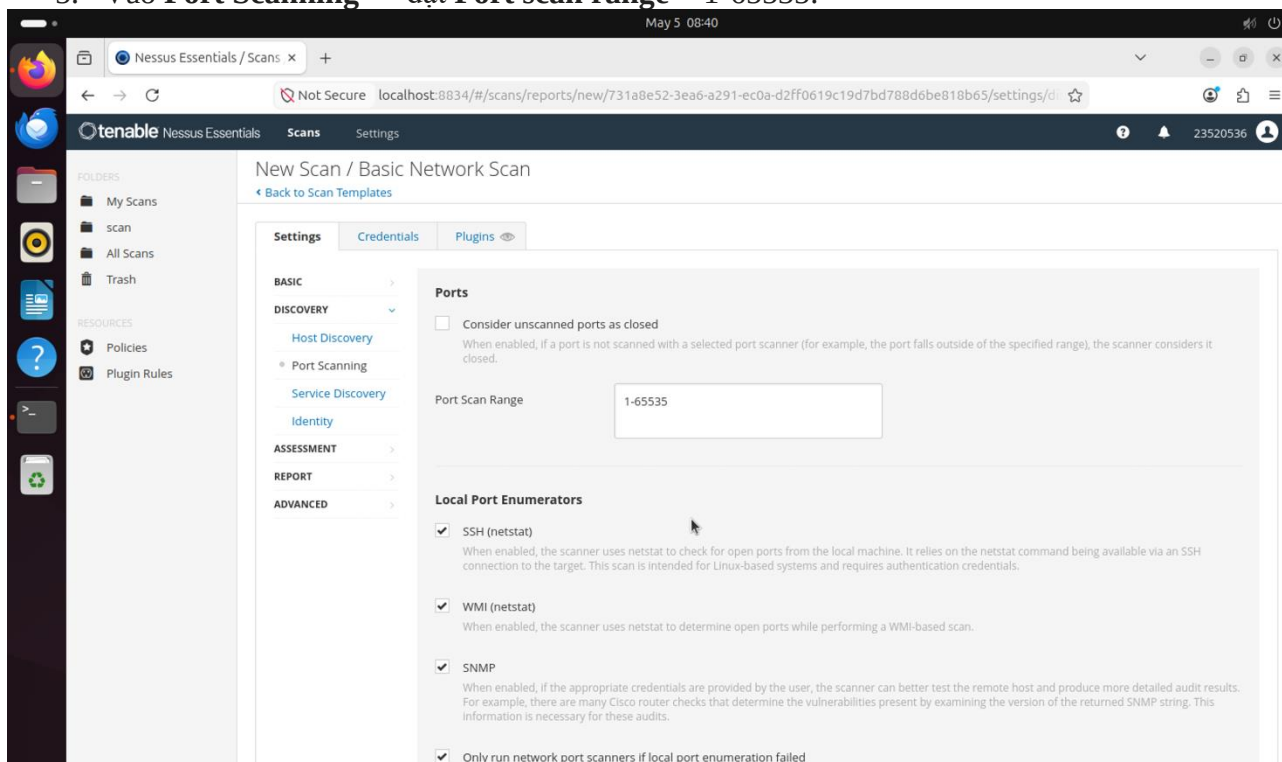
2. Chọn **Basic Network Scan**.
3. Nhập:
 - **Name:** Metasploitable2 - Basic
 - **Targets:** 192.168.125.221



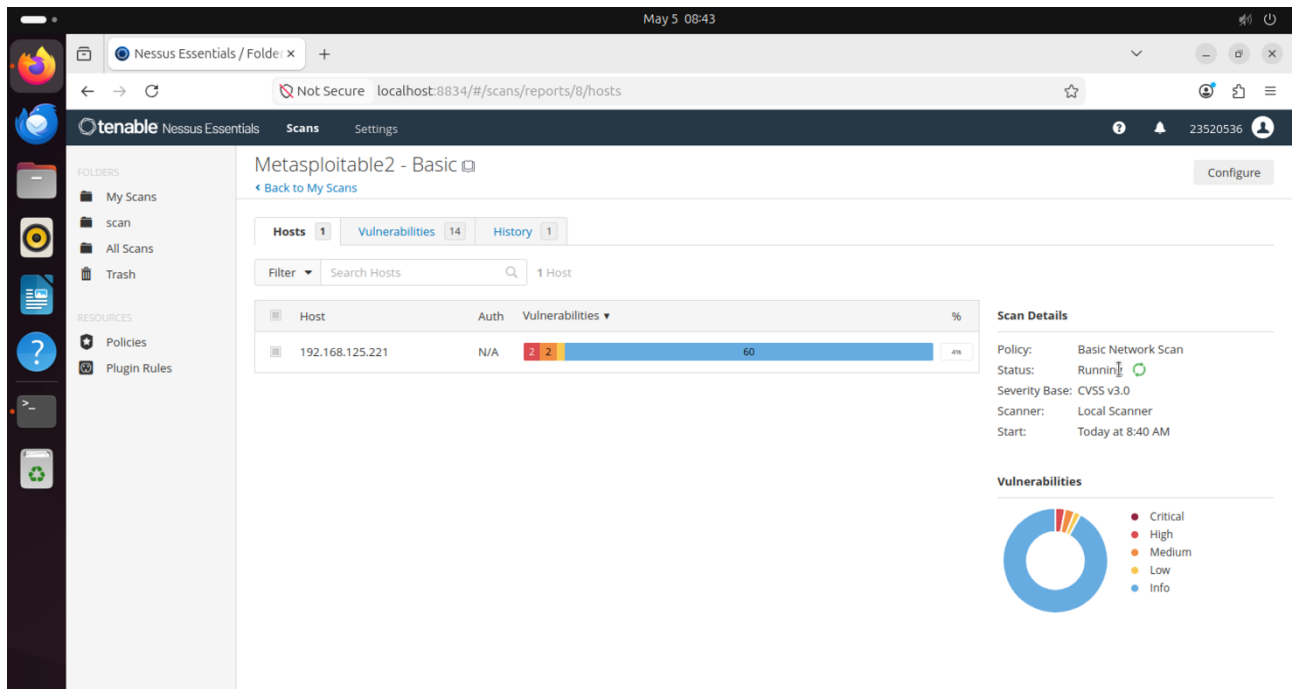
4. Vào **Discovery** → đổi **Scan Type** thành **Custom**.



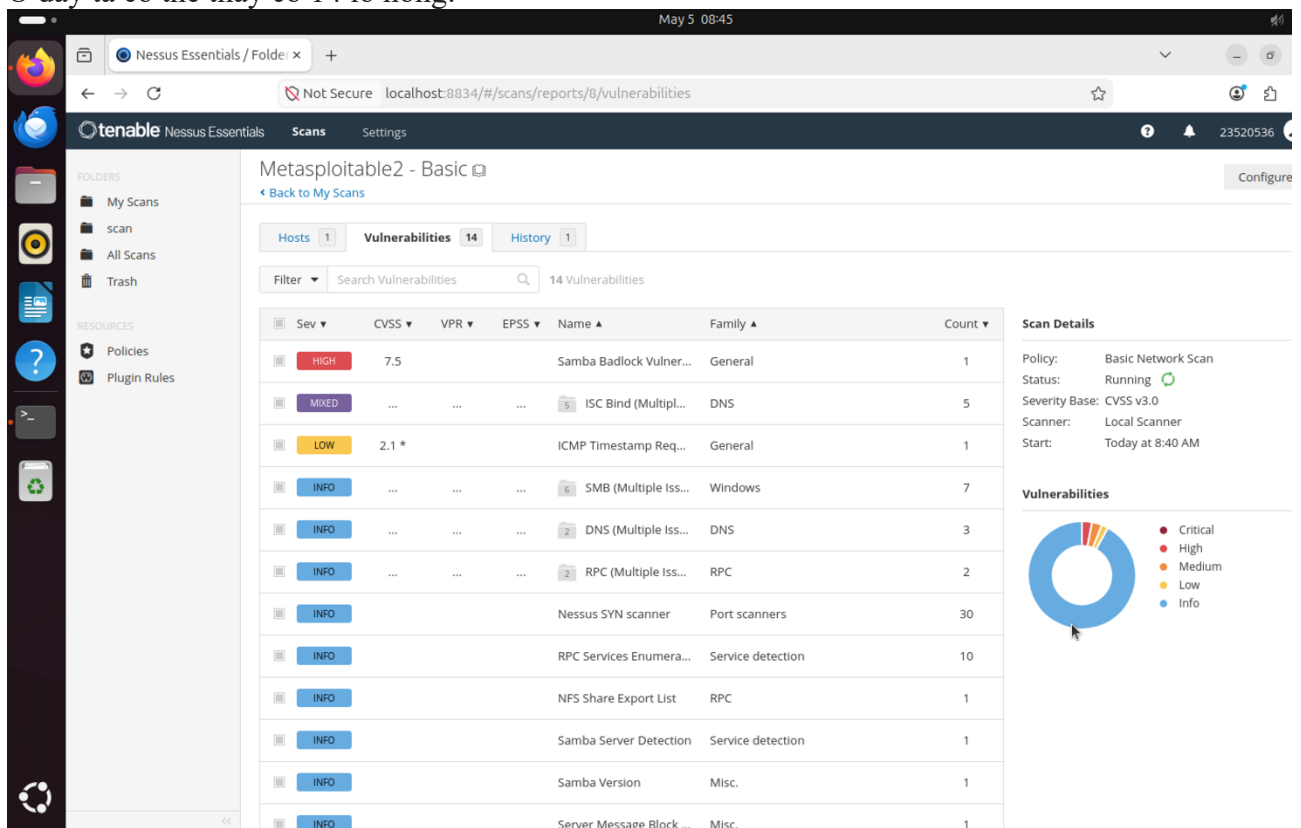
5. Vào **Port Scanning** → đặt **Port scan range** = 1-65535.



6. Click **Save** → quay lại My Scans → Click **Launch**.



Ở đây ta có thể thấy có 14 lỗ hổng:



Một số lỗ hổng điển hình phát hiện được:

1. Samba Badlock Vulnerability (Plugin #90509) - High

- Mô tả: Lỗ hổng trong Samba cho phép attacker thực thi mã từ xa.
- Port: 445/tcp (SMB)
- Giải pháp: Upgrade Samba lên phiên bản 4.2.11 / 4.3.8 / 4.4.2 trở lên.

The screenshot displays the Nessus Essentials web interface in a browser. The address bar shows the URL: `localhost:8834/#/scans/reports/8/vulnerabilities/90509`. The page title is "Metasploitable2 - Basic / Plugin #90509". The left sidebar contains navigation options like "My Scans", "scan", "All Scans", "Trash", "Policies", and "Plugin Rules". The main content area shows a "HIGH" severity vulnerability titled "Samba Badlock Vulnerability".

Description: The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also: <https://www.samba.org/samba/security/CVE-2016-2118.html>

Output: Nessus detected that the Samba Badlock patch has not been applied. To see debug logs, please visit individual host.

Port	Hosts
445 / tcp / cifs	192.168.125.221

Plugin Details:

- Severity: High
- ID: 90509
- Version: 1.9
- Type: remote
- Family: General
- Published: April 13, 2016
- Modified: November 17, 2025

Risk Information:

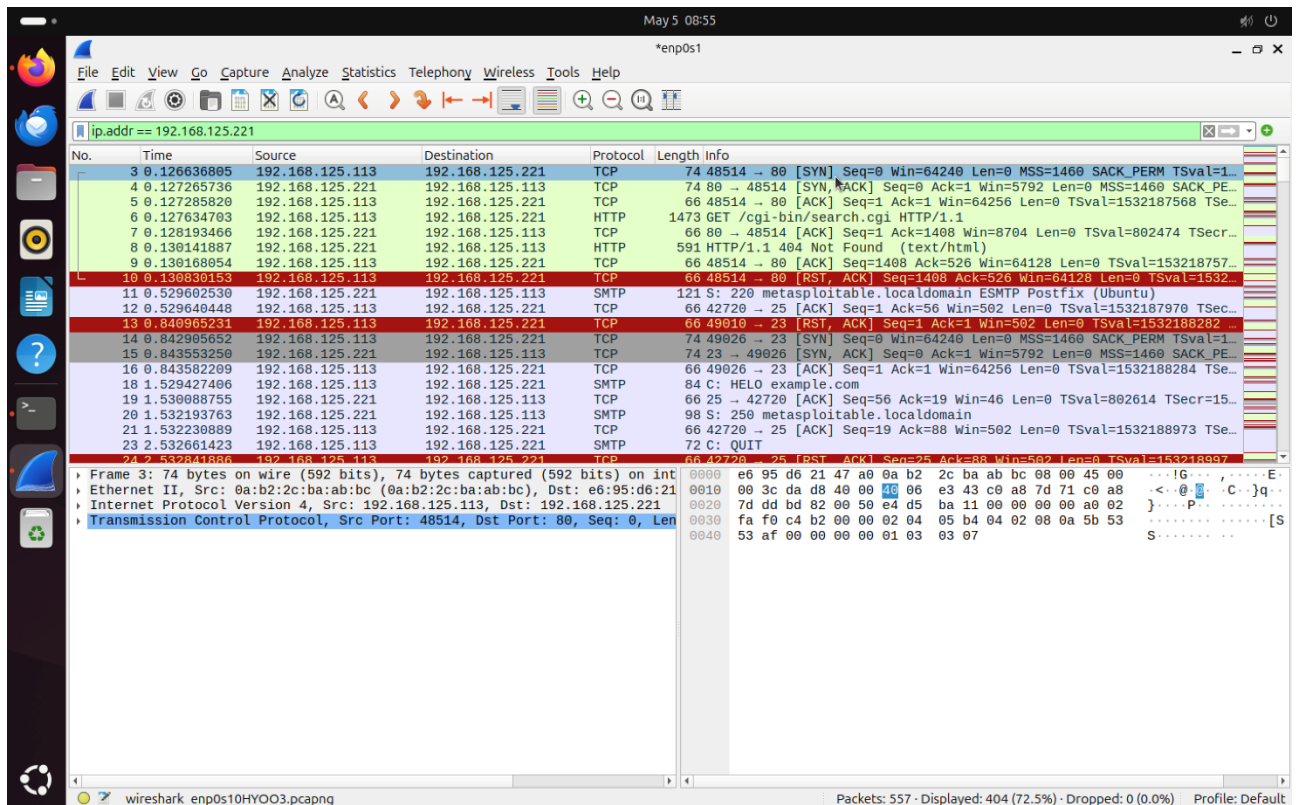
- Risk Factor: Medium
- CVSS v3.0 Base Score: 7.5
- CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
- CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RC:C
- CVSS v3.0 Temporal Score: 6.5
- CVSS v2.0 Base Score: 6.8
- CVSS v2.0 Temporal Score: 5.0
- CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:P
- CVSS v2.0 Temporal Vector: CVSS2#E:U/RL:OF/RC:C

Vulnerability Information

2.1.2 Wireshark:

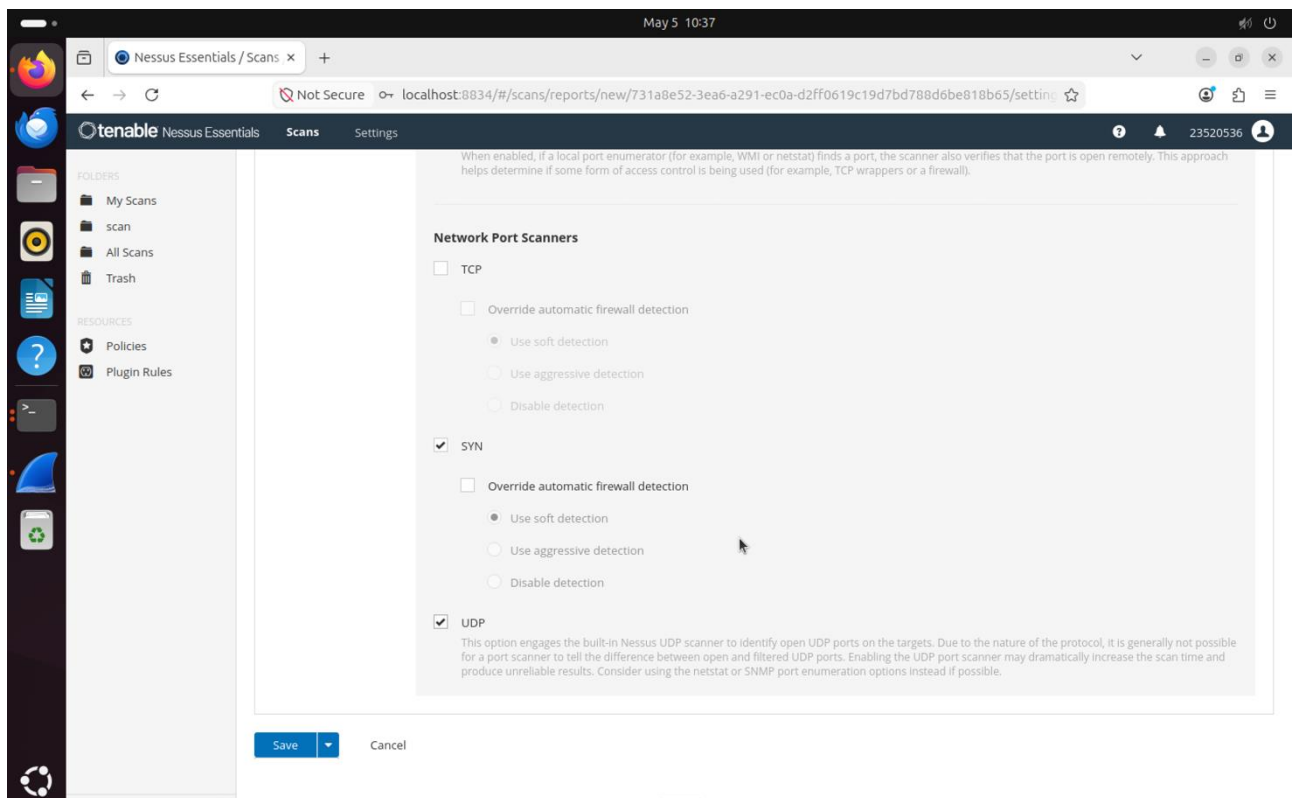
Phân tích lưu lượng với Wireshark

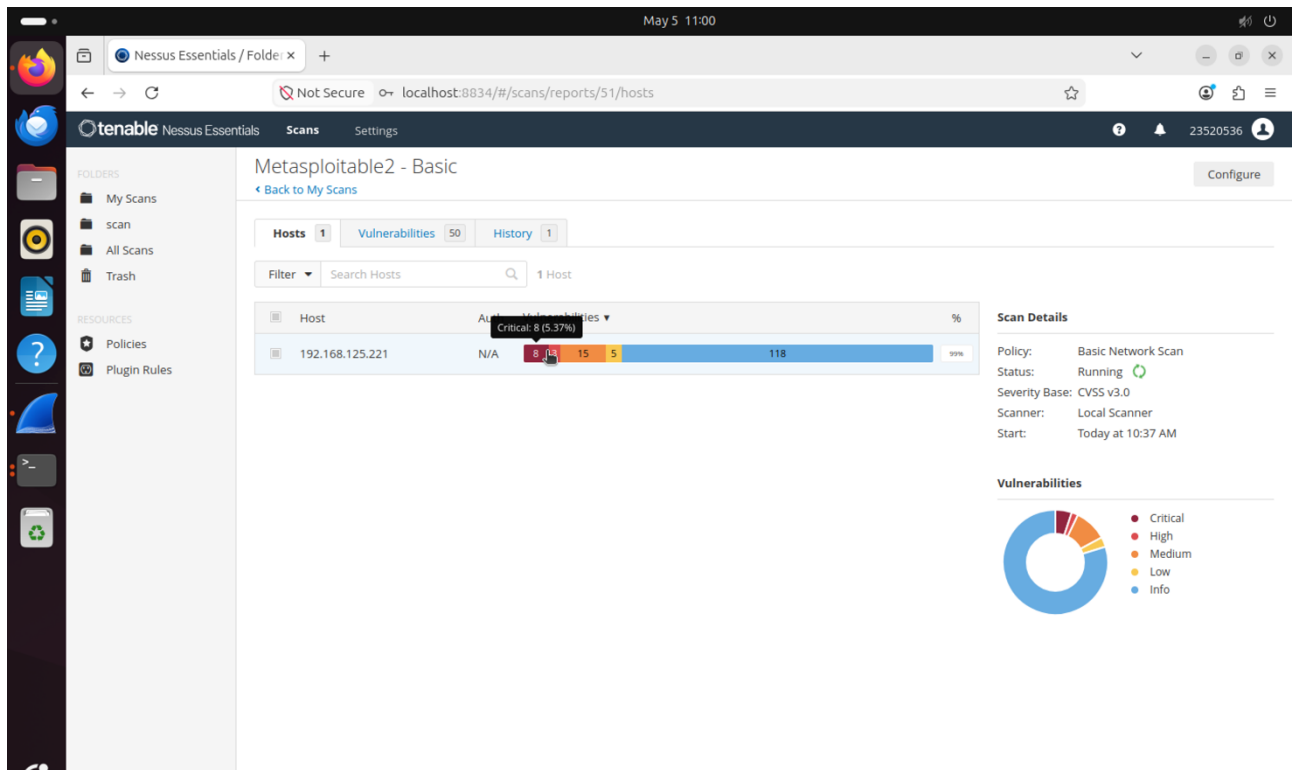
- Wireshark được bật trước khi chạy scan.
- Nessus thực hiện quét bằng cách gửi nhiều gói tin TCP SYN để dò port.
- Phát hiện traffic chủ yếu trên các port: 445 (SMB), 80/443 (HTTP), 25 (SMTP),...



Kết luận: Qua Wireshark có thể thấy Nessus hoạt động chủ yếu dựa trên kỹ thuật quét port (Port Scanning) và thu thập thông tin dịch vụ đang chạy trên máy mục tiêu.

2.1.3 Quét lại với UDP

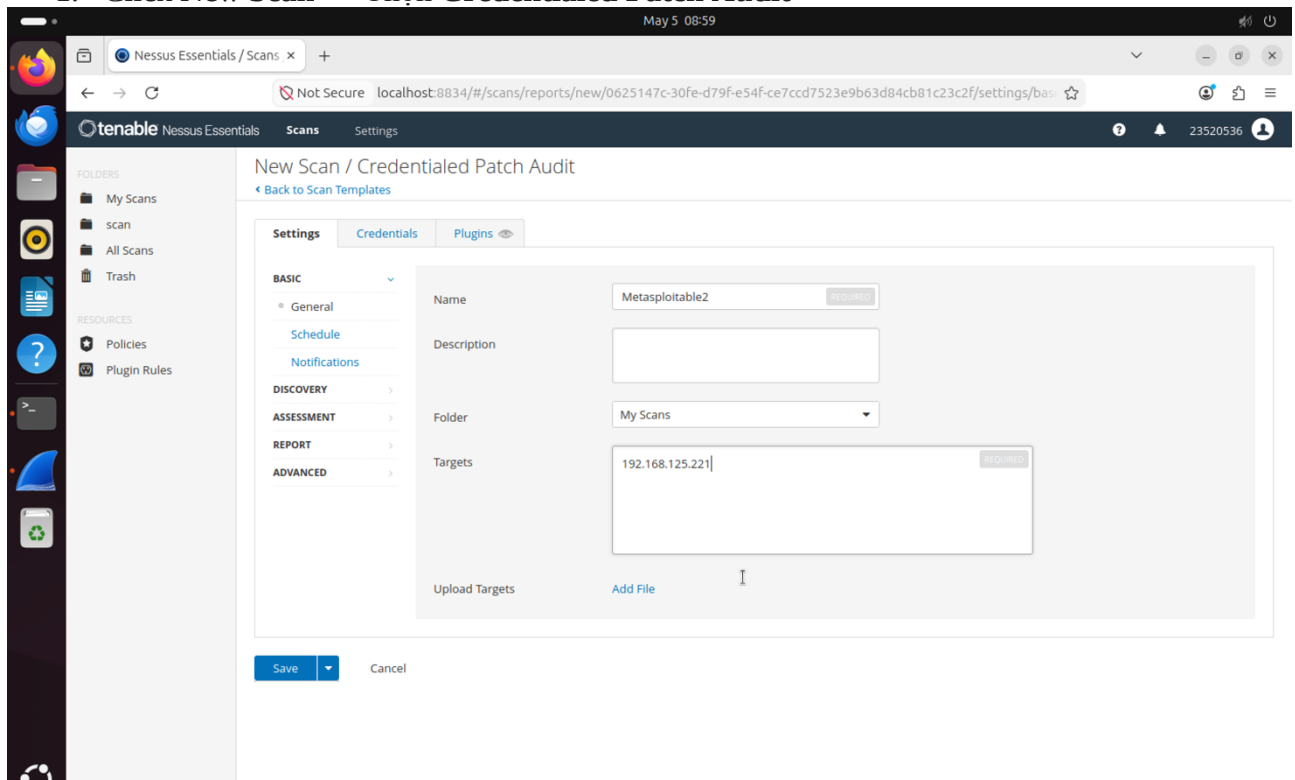




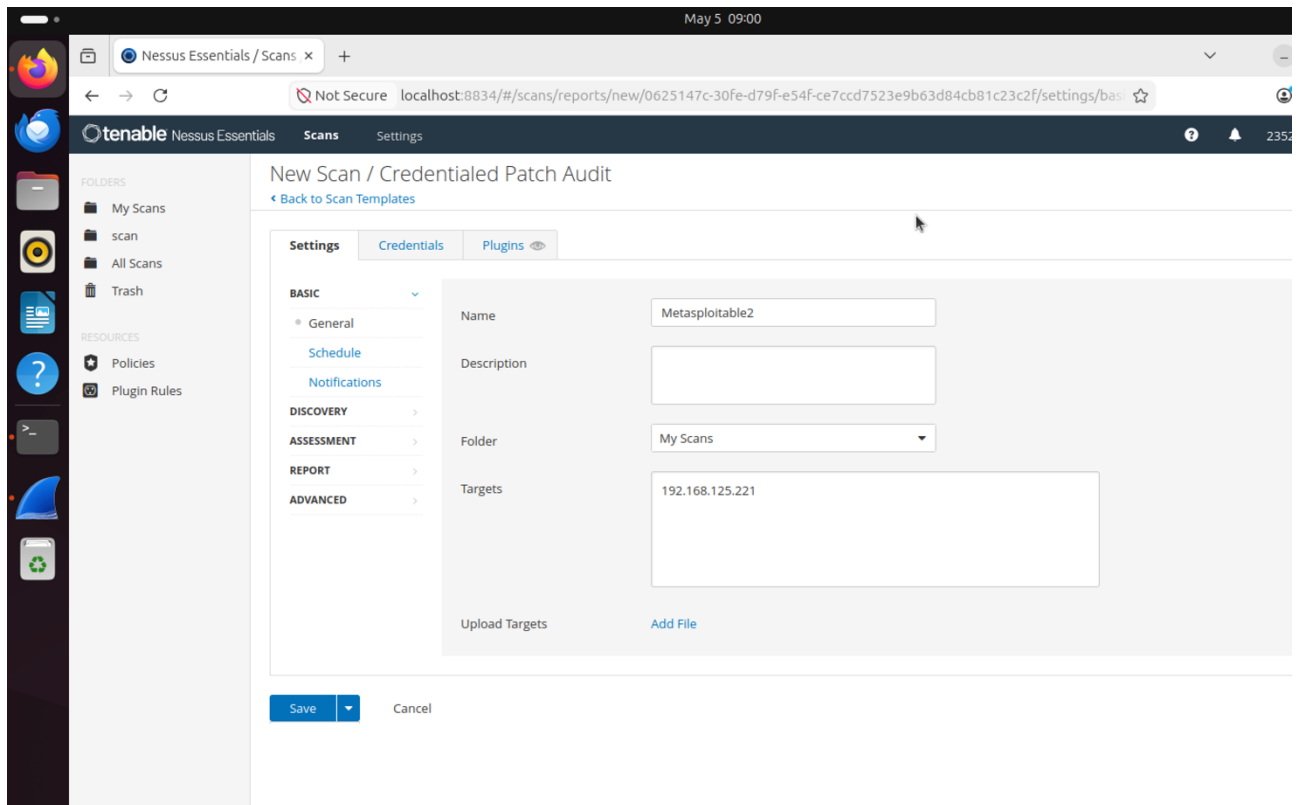
2.2. Nhiệm vụ 2.2 – Quét lỗ hổng sử dụng tài khoản chứng thực

2.2.1 Các bước thực hiện:

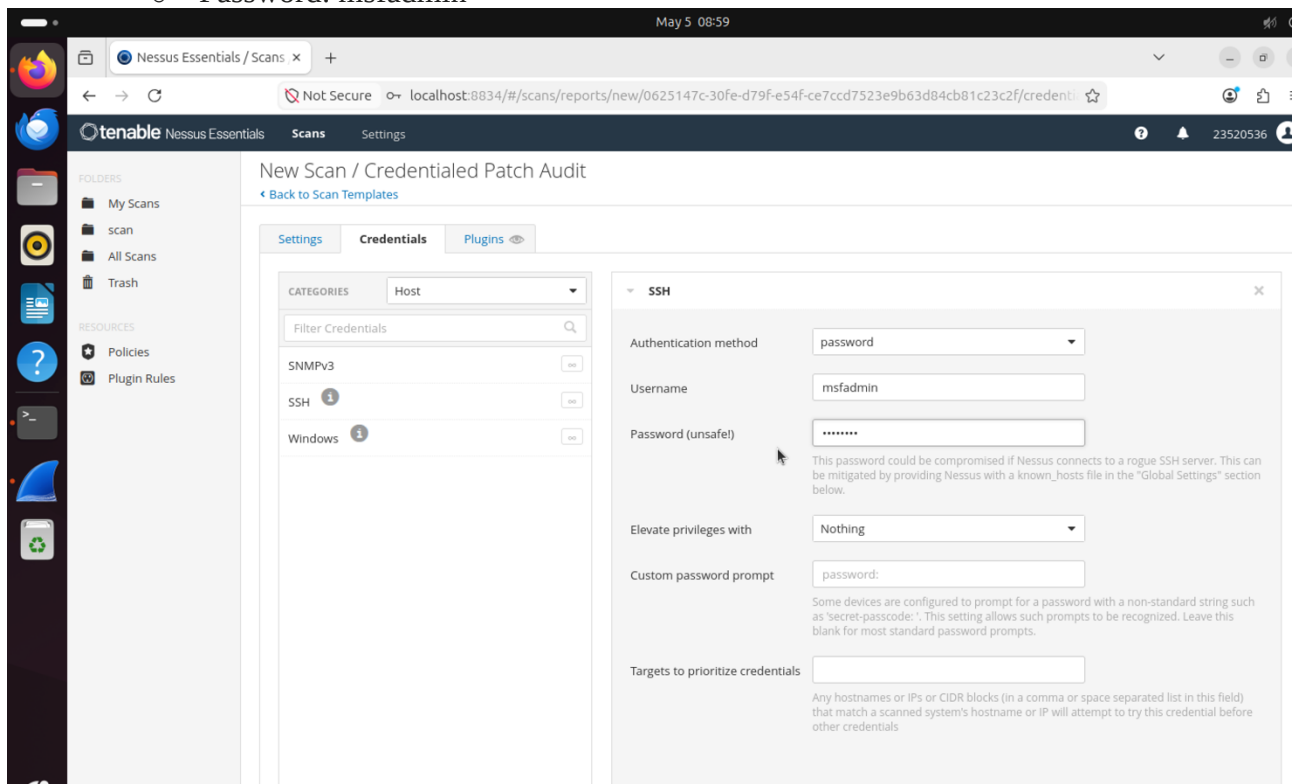
1. Click New Scan → Chọn Credentialed Patch Audit



2. Nhập Name: Metasploitable2 - Auth, Targets: 192.168.125.221.



3. Chuyển sang tab **Credentials**:
 - Chọn **SSH** → **Password**
 - Username: msfadmin
 - Password: msfadmin



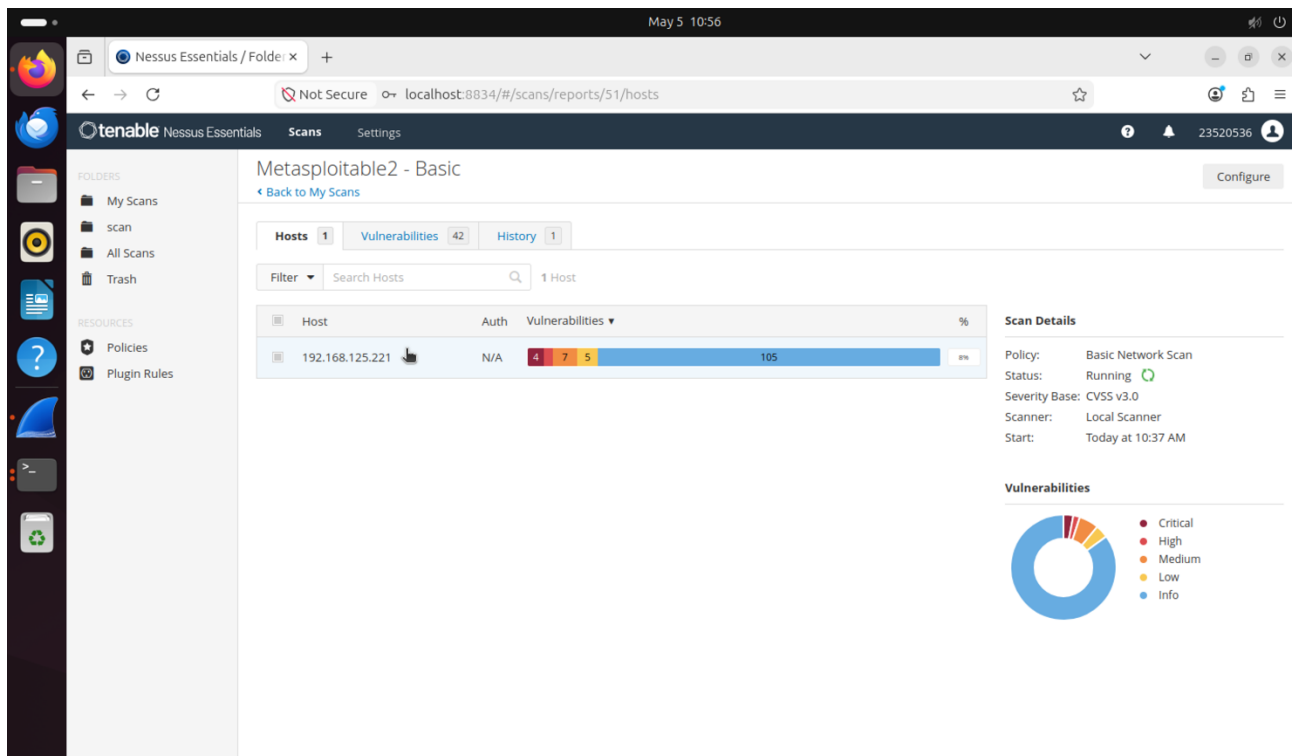
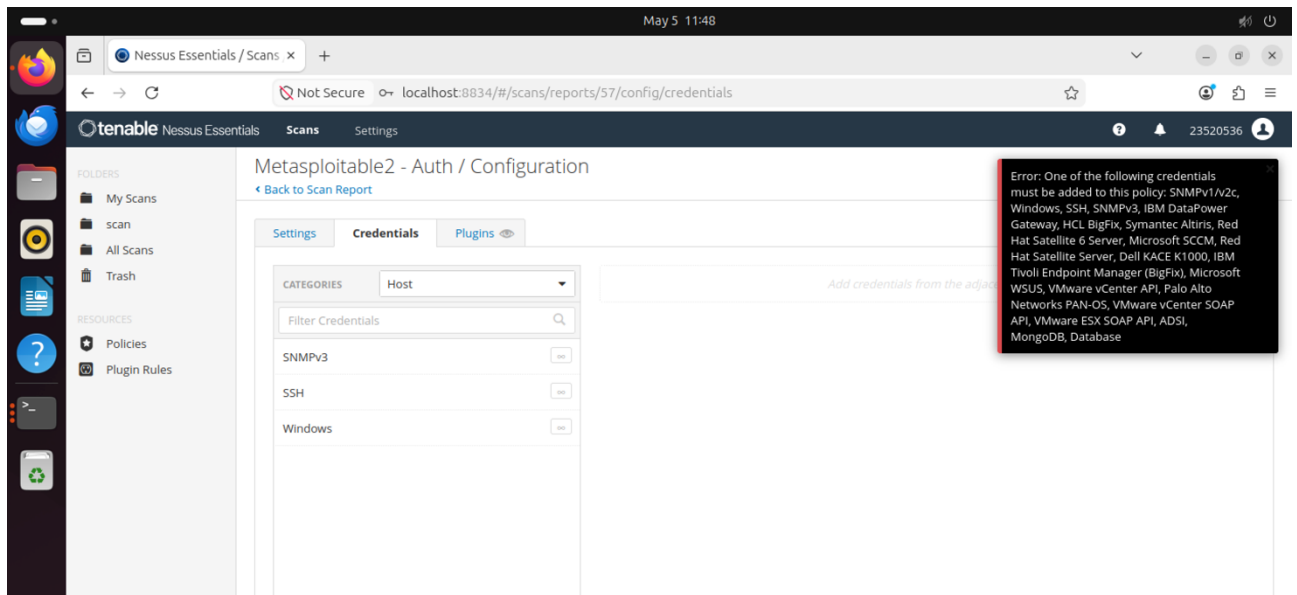
4. Save → Launch.

The top screenshot shows the 'Hosts' tab for the scan 'Metasploitable2 - Auth'. It displays a single host with IP 192.168.125.221 and a 'Pass' authentication status. The 'Vulnerabilities' tab shows a bar chart with 17 Critical, 88 High, 115 Medium, 9 Low, and 57 Info vulnerabilities. The 'Scan Details' section indicates the policy is 'Credentialed Patch Audit', status is 'Completed', and the scan took 18 minutes.

The bottom screenshot shows the 'Vulnerabilities' tab for the same scan. It lists 10 vulnerabilities, including 'CanorUbuntu Local Security Checks' (229 instances), 'SMB (Windows)' (7 instances), and 'Netst...' (42 instances). The 'Scan Details' section shows the policy is 'Credentialed Patch Audit', status is 'Completed', and the scan took 18 minutes.

2.2.2 So sánh kết quả

Vì khi quét không sử dụng tài khoản chứng thực gây lỗi nên ta sẽ dùng quét basic



So sánh giữa hai phương pháp quét:

Tiêu chí	Non-Credentialed	Credentialed	Nhận xét
Số lỗ hổng phát hiện	Nhiều	Ít hơn	Credentialed phát hiện sâu hơn
Độ chính xác	Thấp, nhiều false positive	Cao hơn	Có thông tin từ bên trong máy
Loại lỗ hổng	Chủ yếu Remote	Remote + Local + Patch missing	Phát hiện được lỗ hổng cục bộ
Thời gian scan	Nhanh	Lâu hơn	Phải login SSH

Tiêu chí	Non-Credentialed	Credentialed	Nhận xét
Rủi ro với hệ thống mục tiêu	Thấp	Cao hơn (có thể gây crash)	Cần xin phép quản trị viên

2.2.3 Ưu và nhược điểm

Ưu điểm của quét có chứng thực:

- Phát hiện nhiều lỗ hổng cục bộ (local vulnerabilities).
- Giảm đáng kể false positive.
- Biết được phiên bản phần mềm, patch level chính xác.
- Phát hiện lỗ hổng mà không cần exploit từ xa.

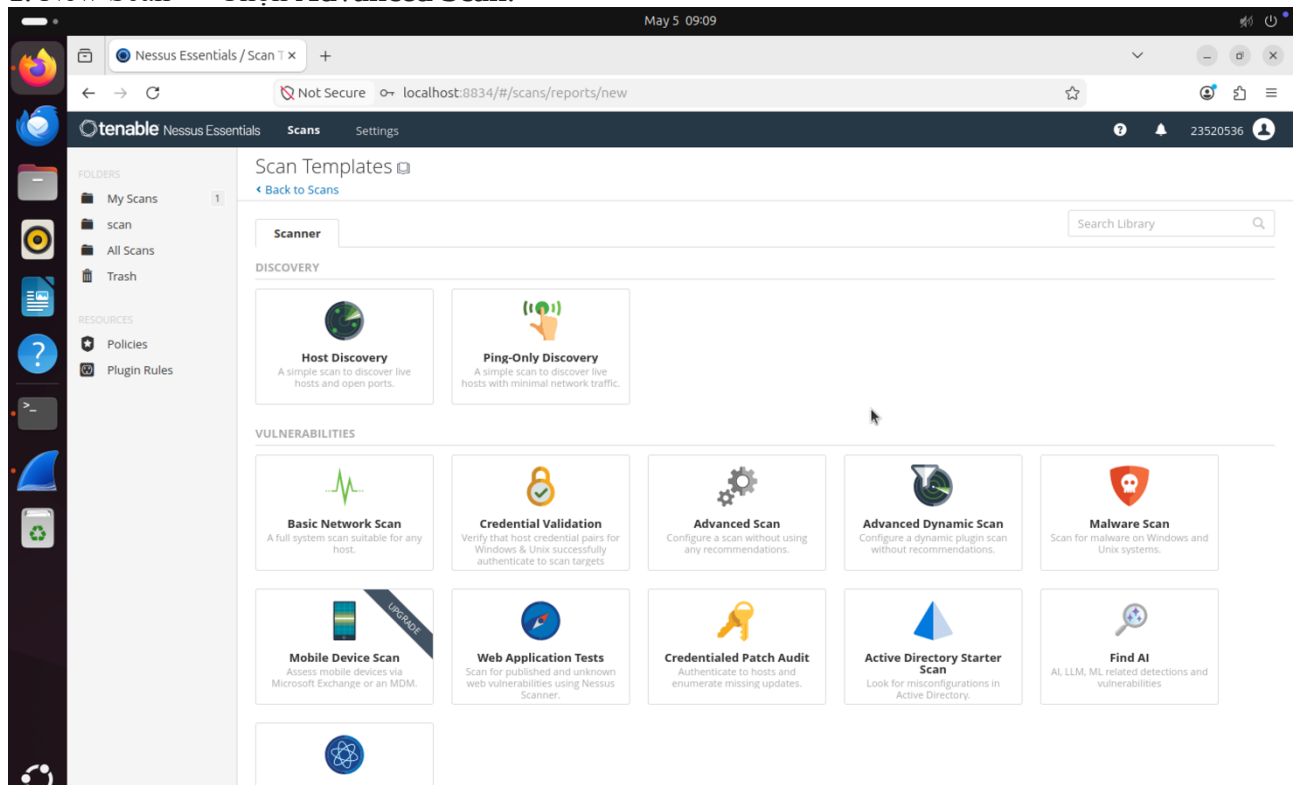
Nhược điểm của quét có chứng thực:

- Cần có tài khoản hợp lệ trên máy mục tiêu.
- Tăng nguy cơ làm ảnh hưởng đến hệ thống (có thể gây crash dịch vụ).
- Không thực tế trong môi trường pentest thực tế (thường không được cấp tài khoản).
- Tốn nhiều thời gian hơn.

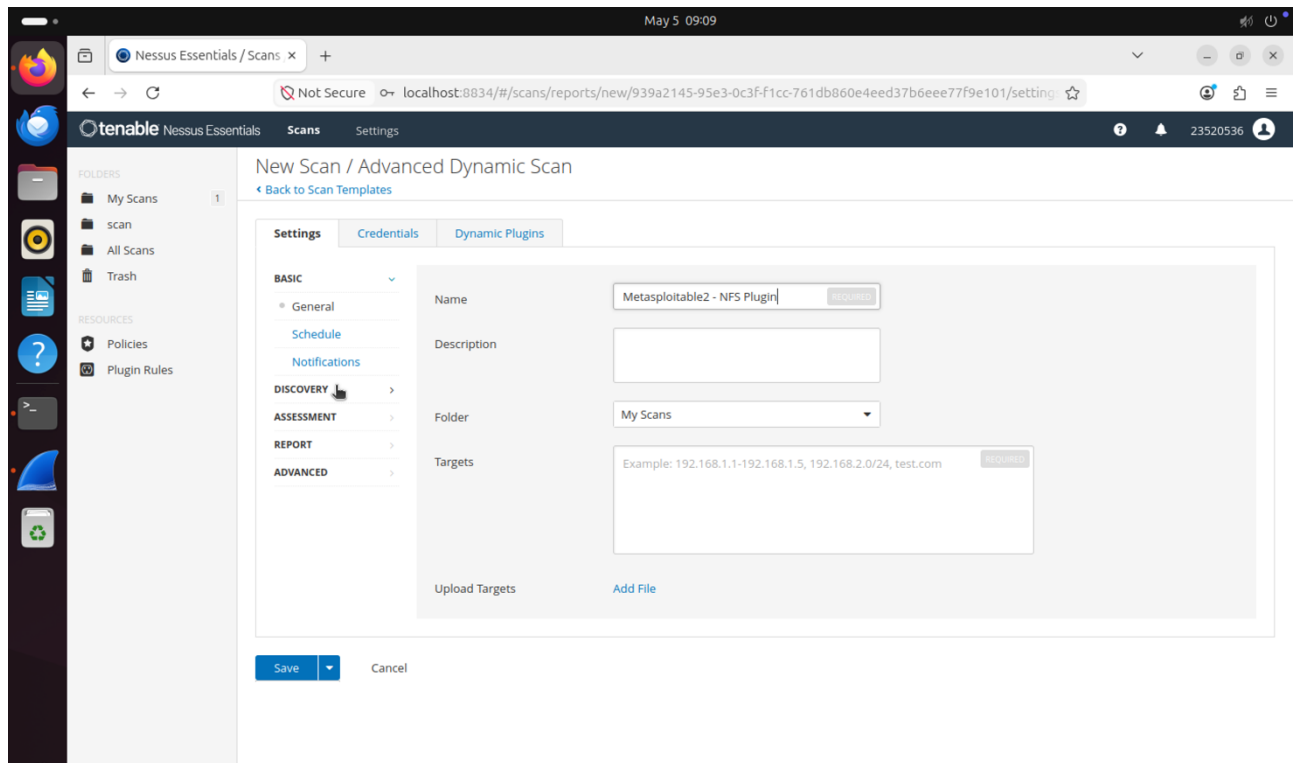
2.3. Nhiệm vụ 2.3 – Quét với Plugin được chỉ định

2.3.1 Các bước thực hiện:

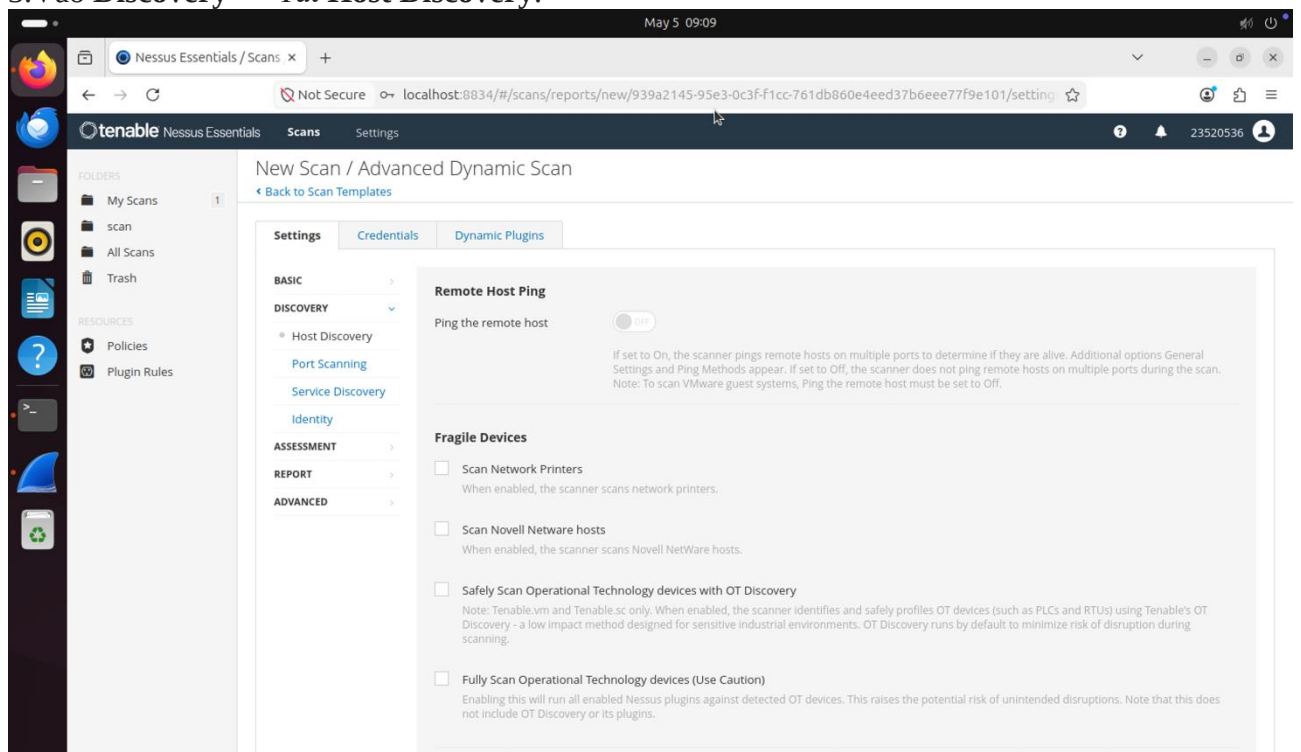
1. New Scan → Chọn Advanced Scan.



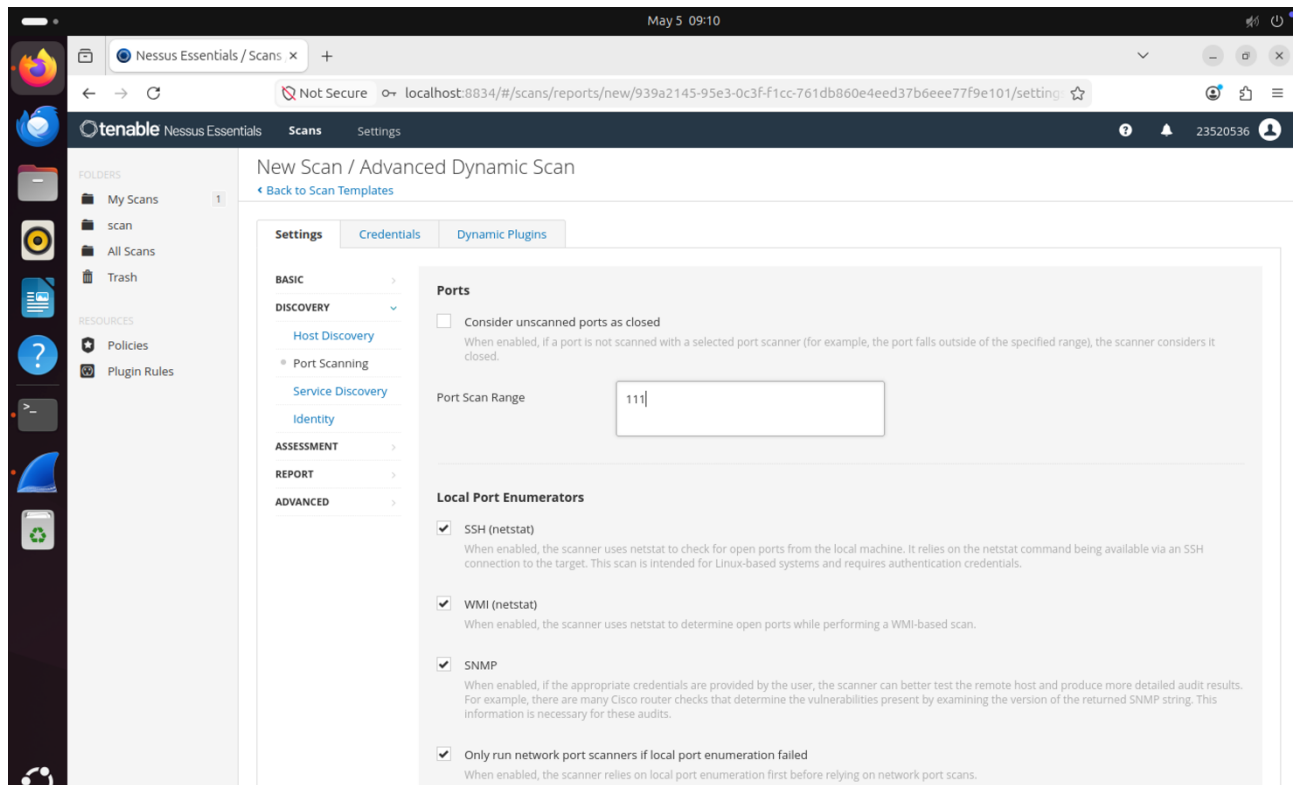
2.Name: Metasploitable2 - NFS Plugin.



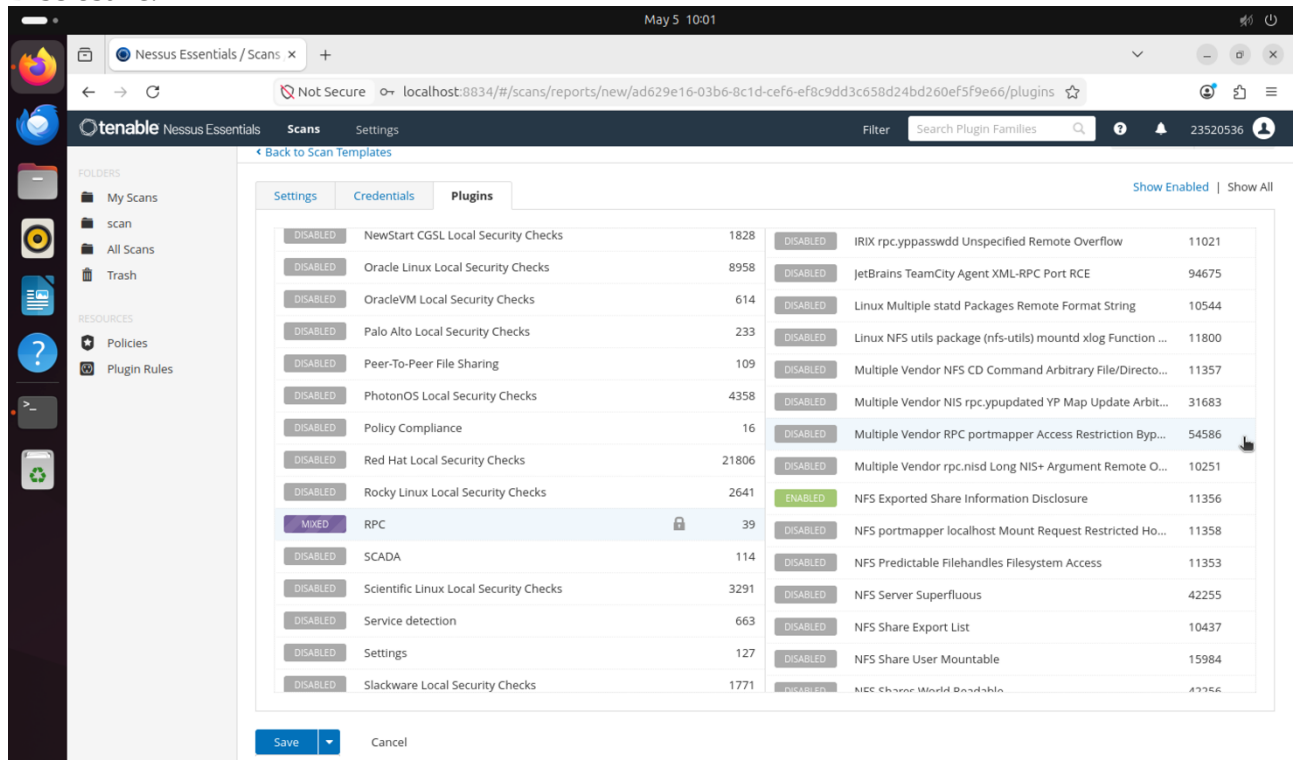
3. Vào **Discovery** → **Tắt Host Discovery**.



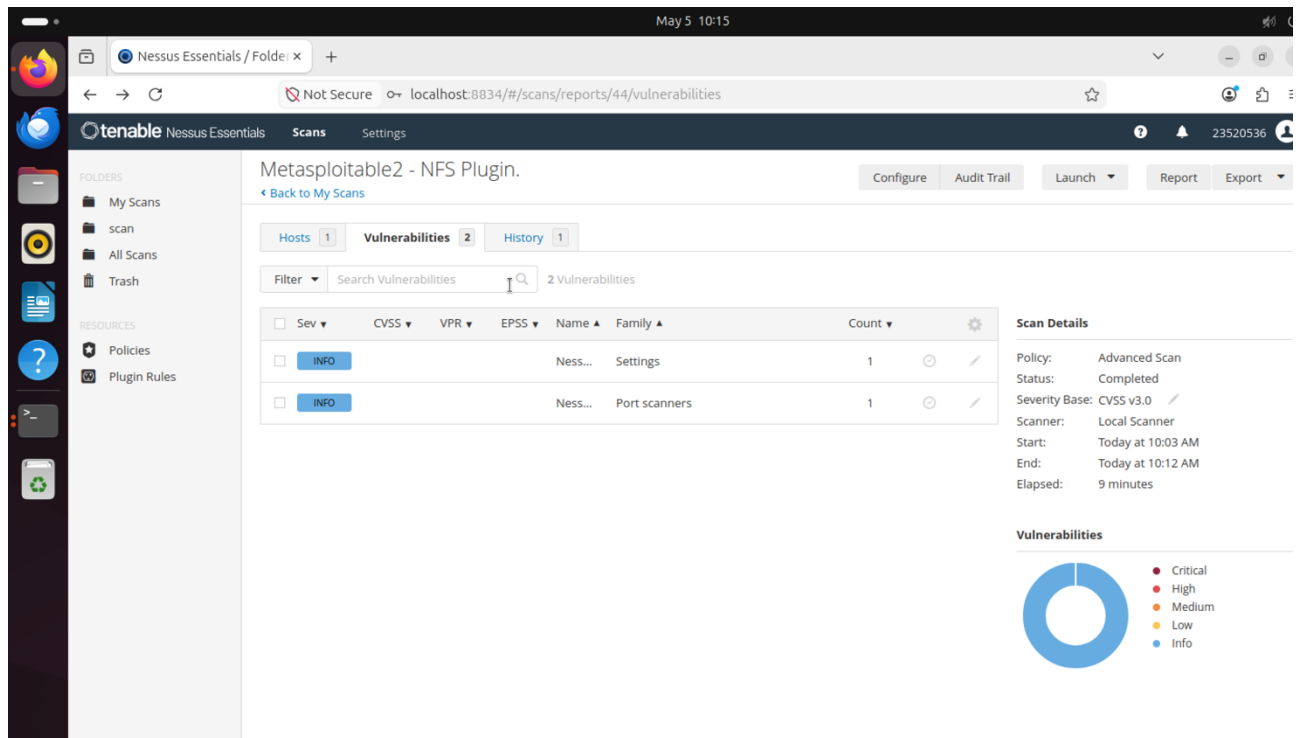
4. Vào **Port Scanning** → Port scan range: 111.



5. Tab **Plugins** → **Disable All** → **Tìm RPC** → **Enable NFS Exported Share Information Disclosure**.

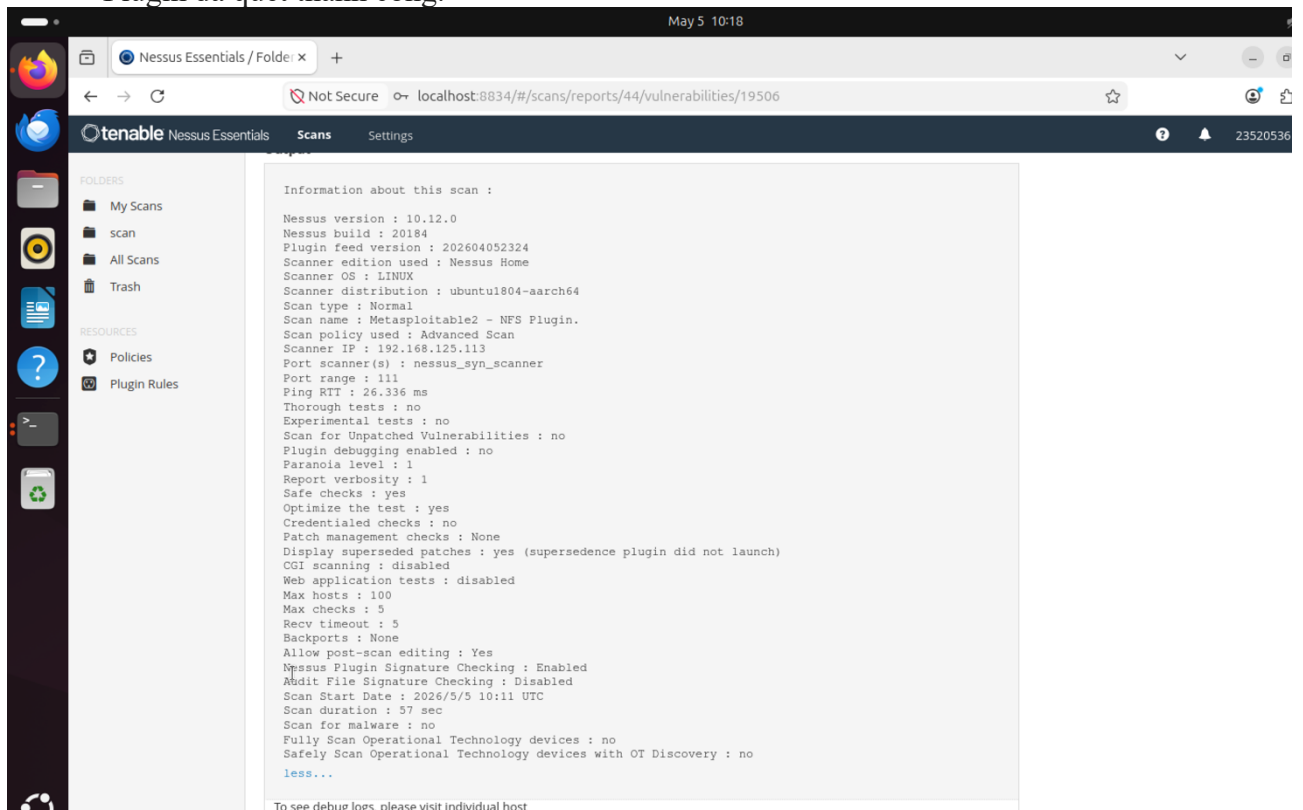


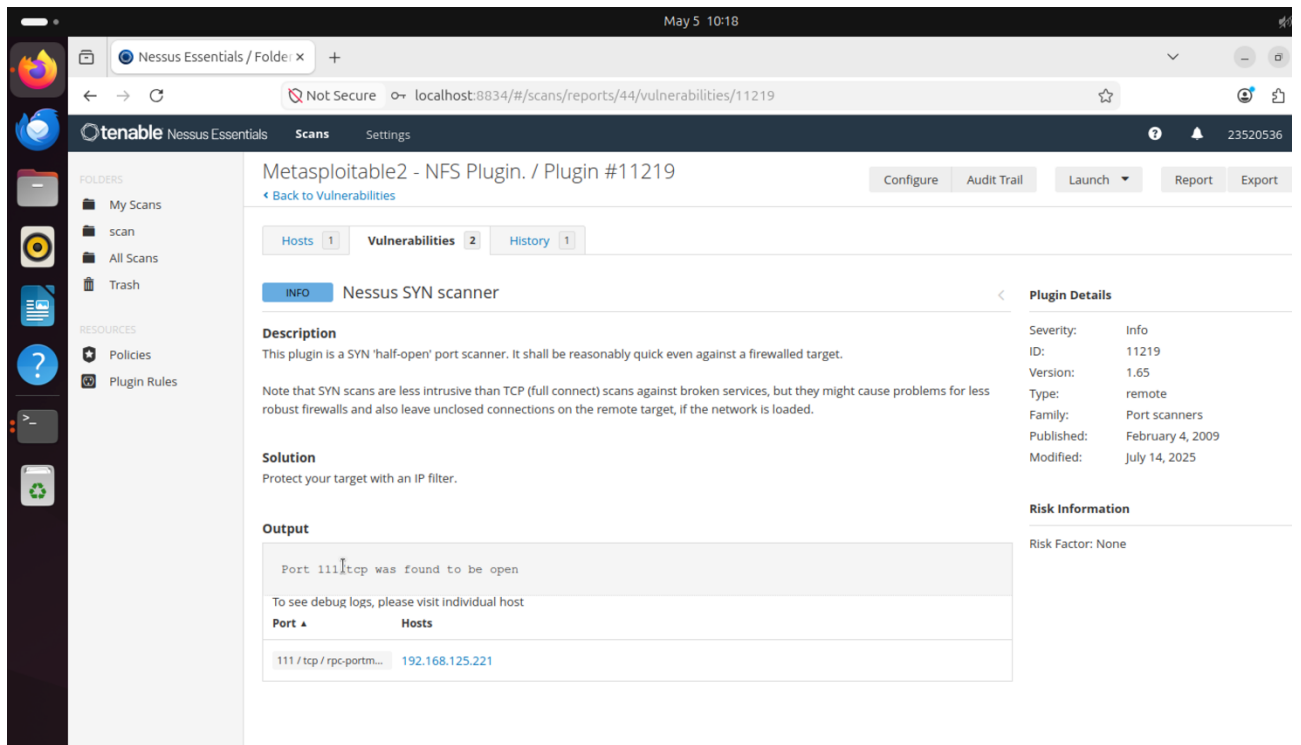
6. **Save** → **Launch**.



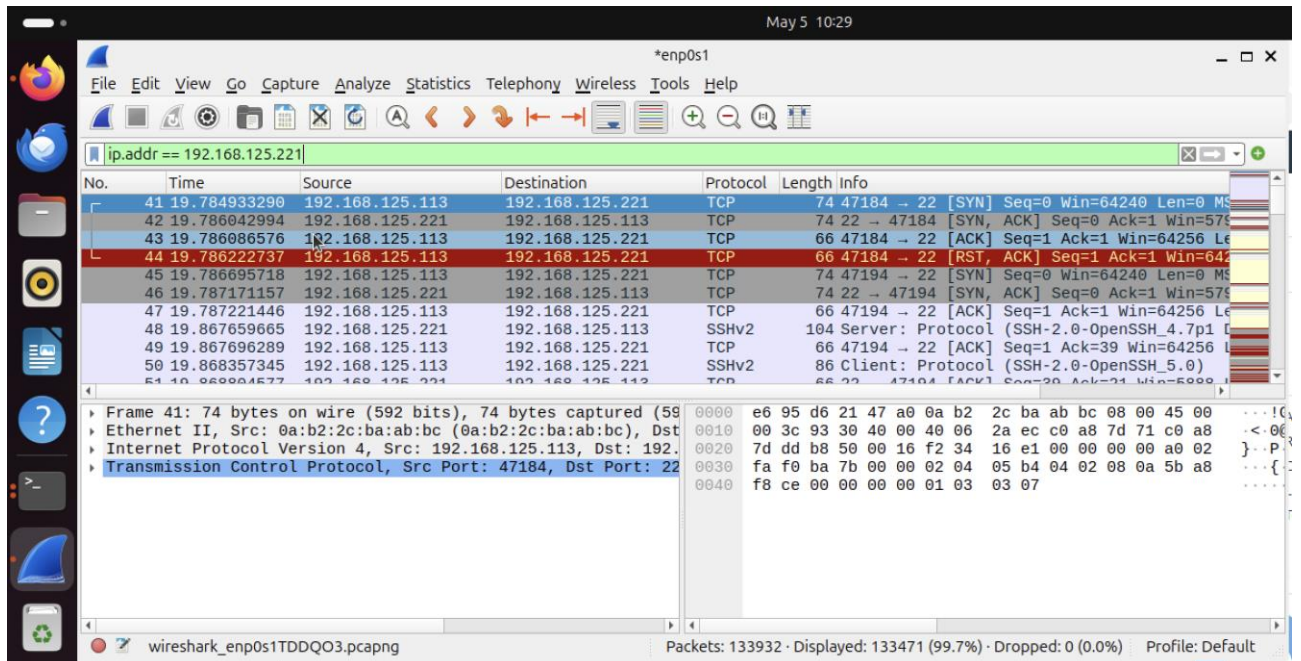
Kết quả:

- Số host: 1
- Số lỗ hổng phát hiện: 2 (mức độ Info)
- Plugin đã quét thành công.



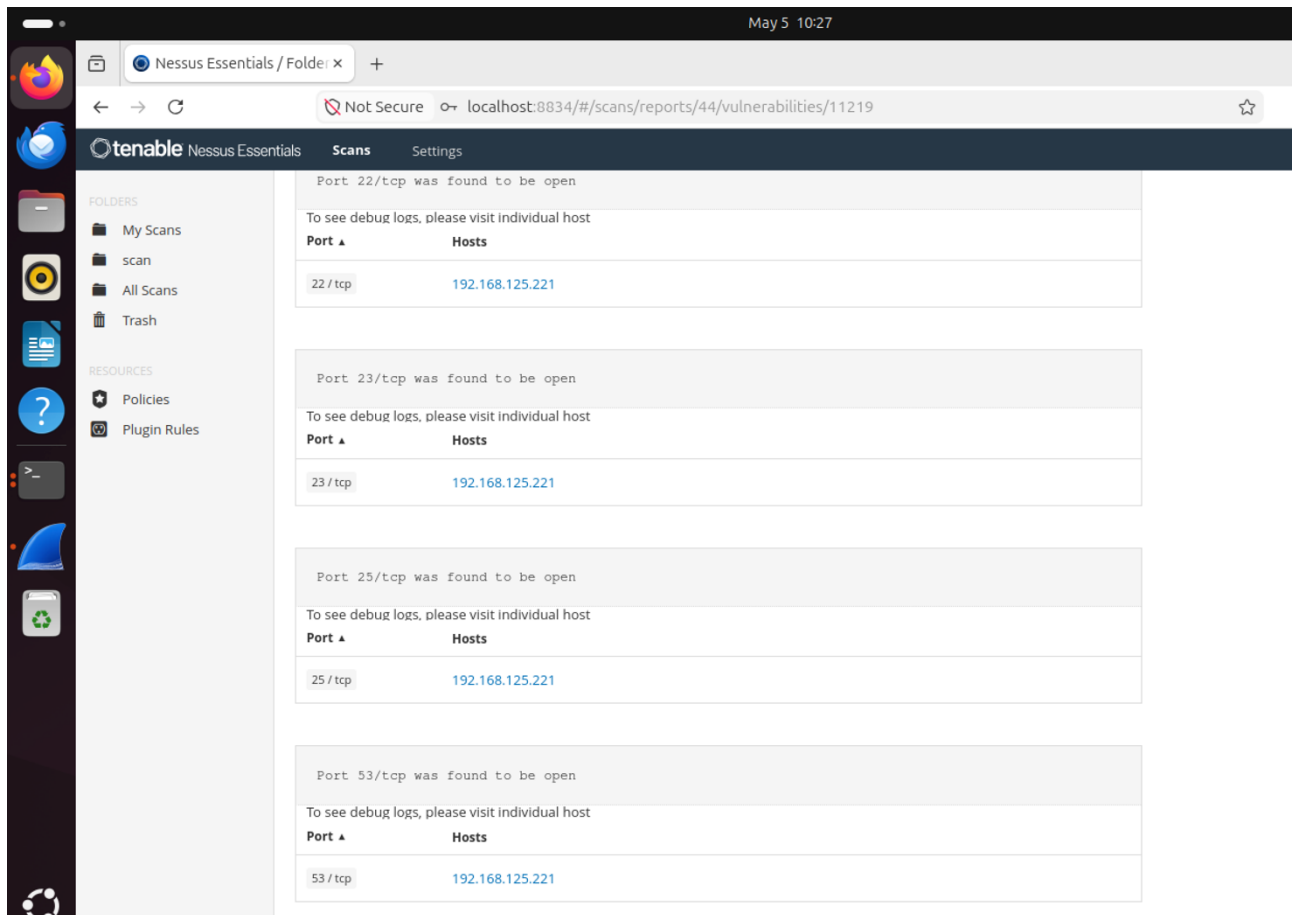


2.3.2 Wireshark:



Tại sao Nessus vẫn scan các port khác dù chỉ định port 111?

→ Vì Nessus mặc định vẫn thực hiện một số bước **Discovery** và **Service Detection** ngay cả khi bạn giới hạn port scan range. Nó dùng một số plugin hệ thống để thu thập thông tin cơ bản trước khi chạy plugin chính.



2.3.3. Cách ngăn chặn Nessus scan các port khác

Để buộc Nessus chỉ quét đúng port 111:

1. Vào **Settings** → **Discovery** → **Port Scanning**
2. Chọn **Port scan range**: 111
3. Trong **Local Port Enumerators**:
 - **Bỏ tick** tất cả các tùy chọn (SSH netstat, WMI, SNMP...)
4. Tab **Plugins** → Disable All → Chỉ bật plugin NFS (ID 11356)
5. Tab **Advanced** → Tìm và disable các tùy chọn Discovery không cần thiết.

2.3.4. Thực hiện quét lại với 2 plugin khác

Plugin số 1:

Screenshot 1: Metasploitable2 - NFS Plugin. / Configuration

Disables All | Enable All

Show Enabled | Show All

Plugin Name	Count	Status
DISABLED NewStart CGSL Local Security Checks	1828	DISABLED
DISABLED Oracle Linux Local Security Checks	8958	DISABLED
DISABLED OracleVM Local Security Checks	614	DISABLED
DISABLED Palo Alto Local Security Checks	233	DISABLED
DISABLED Peer-To-Peer File Sharing	109	DISABLED
DISABLED PhotonOS Local Security Checks	4358	DISABLED
DISABLED Policy Compliance	16	DISABLED
DISABLED Red Hat Local Security Checks	21806	DISABLED
DISABLED Rocky Linux Local Security Checks	2641	DISABLED
MIXED RPC	39	MIXED
DISABLED SCADA	114	DISABLED
DISABLED Scientific Linux Local Security Checks	3291	DISABLED
DISABLED Service detection	663	DISABLED
DISABLED Settings	127	DISABLED
DISABLED Slackware Local Security Checks	1771	DISABLED
DISABLED CDE RPC tooltalk Service Multiple Overflows	10239	DISABLED
DISABLED Detect RPC over TCP	53333	DISABLED
DISABLED Detect RPC over UDP	53334	DISABLED
DISABLED IRIX rpc.yppasswdd Unspecified Remote Overflow	11021	DISABLED
DISABLED JetBrains TeamCity Agent XML-RPC Port RCE	94675	DISABLED
DISABLED Linux Multiple statd Packages Remote Format String	10544	DISABLED
ENABLED Linux NFS utils package (nfs-utils) mountd xlog Function ...	11800	ENABLED
DISABLED Multiple Vendor NFS CD Command Arbitrary File/Directo...	11357	DISABLED
DISABLED Multiple Vendor NIS rpc.yppasswdd YP Map Update Arbit...	31683	DISABLED
DISABLED Multiple Vendor RPC portmapper Access Restriction Byp...	54586	DISABLED
DISABLED Multiple Vendor rpc.nisd Long NIS+ Argument Remote O...	10251	DISABLED
DISABLED NFS Exported Share Information Disclosure	11356	DISABLED
DISABLED NFS portmapper localhost Mount Request Restricted Ho...	11358	DISABLED
DISABLED NFS Predictable Filehandles Filesystem Access	11353	DISABLED

Screenshot 2: Metasploitable2 - NFS Plugin.

Configure

Hosts 1 | Vulnerabilities 1 | History 3

Filter Search Hosts 1 Host

Host	Auth	Vulnerabilities	%
192.168.125.221	N/A	30	44%

Scan Details

Policy: Advanced Scan
 Status: Running
 Severity Base: CVSS v3.0
 Scanner: Local Scanner
 Start: Today at 10:31 AM

Vulnerabilities

Donut chart showing severity levels: Critical (red), High (orange), Medium (yellow), Low (light blue), Info (dark blue).

Plugin số 2:

Top Screenshot: Metasploitable2 - NFS Plugin. / Configuration

STATUS	PLUGIN NAME	PLUGIN ID
DISABLED	3270 Mapper Service Detection	10208
DISABLED	Apache Log4Shell RCE detection via callback correlation (...)	156559
DISABLED	CDE RPC tooltalk Service Multiple Overflows	10239
DISABLED	Detect RPC over TCP	53333
DISABLED	Detect RPC over UDP	53334
DISABLED	IRIX rpc.yppasswdd Unspecified Remote Overflow	11021
ENABLED	JetBrains TeamCity Agent XML-RPC Port RCE	94675
DISABLED	Linux Multiple statd Packages Remote Format String	10544
DISABLED	Linux NFS utils package (nfs-utils) mountd xlog Function ...	11800
DISABLED	Multiple Vendor NFS CD Command Arbitrary File/Directo...	11357
DISABLED	Multiple Vendor NIS rpc.yppupdated YP Map Update Arbit...	31683
DISABLED	Multiple Vendor RPC portmapper Access Restriction Byp...	54586
DISABLED	Multiple Vendor rpc.nisd Long NIS+ Argument Remote O...	10251

Bottom Screenshot: Metasploitable2 - NFS Plugin.

Sev	CVSS	VPR	EPSS	Name	Family	Count
INFO				Nessus SYN scanner	Port scanners	30

Scan Details

- Policy: Advanced Scan
- Status: Running
- Severity Base: CVSS v3.0
- Scanner: Local Scanner
- Start: Today at 10:34 AM

Vulnerabilities

- Critical
- High
- Medium
- Low
- Info

- a) 2.4. Nhiệm vụ 2.4: Tìm hiểu một công cụ quét lỗ hổng khác
- Công cụ chọn: Trivy
- 2.4.1. Giới thiệu về Trivy
- Trivy là công cụ quét lỗ hổng mã nguồn mở được phát triển bởi Aqua Security. Công cụ này chuyên dùng để phát hiện các lỗ hổng bảo mật trong hệ thống, thư viện phần mềm và container. Trivy hỗ trợ quét nhiều đối tượng khác nhau như hệ điều hành (OS packages), Docker image, source code và các dependencies.

b) Ưu điểm:

- Miễn phí hoàn toàn
- Cài đặt đơn giản, dễ sử dụng
- Tốc độ quét nhanh
- Không cần cấu hình phức tạp
- Hỗ trợ nhiều loại mục tiêu (filesystem, container, repo)

c) Nhược điểm:

- Không mạnh về quét mạng như Nessus
- Không có giao diện web (chạy CLI)
- Ít tính năng nâng cao hơn các công cụ thương mại

2.4.2. Quá trình cài đặt và sử dụng Trivy**1. Cài đặt trên Ubuntu/Kali:**

```
hacker@23520536:~$ sudo apt-get update
sudo apt-get install trivy -y
Get:1 https://aquasecurity.github.io/trivy-repo/deb noble InRelease [3,235 B]
Hit:2 http://ports.ubuntu.com/ubuntu-ports noble InRelease
Get:3 https://aquasecurity.github.io/trivy-repo/deb noble/main arm64 Packages [3
57 B]
Hit:4 http://ports.ubuntu.com/ubuntu-ports noble-updates InRelease
Hit:5 http://ports.ubuntu.com/ubuntu-ports noble-backports InRelease
Hit:6 http://ports.ubuntu.com/ubuntu-ports noble-security InRelease
Fetched 3,592 B in 2s (1,464 B/s)
Reading package lists... Done
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following NEW packages will be installed:
trivy
```

Kiểm tra cài đặt:

```
hacker@23520536:~$ trivy --version
Version: 0.70.0
hacker@23520536:~$
```

2. Thực hiện quét:

Quét toàn bộ hệ thống:

```
trivy fs /
```

Hoặc quét thư mục cụ thể:

```
trivy fs /home
```

2.4.3. Thực hiện quét trên hệ thống**• Chạy lệnh quét:**

```
hacker@23520536:~$ trivy fs /
2026-05-05T12:52:40Z INFO [vulndb] Need to update DB
2026-05-05T12:52:40Z INFO [vulndb] Downloading vulnerability DB...
2026-05-05T12:52:40Z INFO [vulndb] Downloading artifact... repo="mi
rror.gcr.io/aquasec/trivy-db:2"
61.78 MiB / 91.14 MiB [----->] 67.79% 1.91 MiB p/s ETA 15s
```

- Công cụ sẽ tự động:
 - Tải database lỗ hổng
 - Phân tích hệ thống
 - Hiển thị kết quả
- Kết quả bao gồm:

- Danh sách lỗ hổng (CVE)
- Mức độ nguy hiểm:
 - LOW
 - MEDIUM
 - HIGH
 - CRITICAL
- Phiên bản bị ảnh hưởng
- Phiên bản đã được vá

```

May 5 12:57
hacker@23520536: ~
| wireshark: Improper Handling of Missing Values in Wireshark |
| https://avd.aquasec.com/nvd/cve-2024-9781 |
|
| wireshark: Uncontrolled Recursion in Wireshark | CVE-2025-1492 |
| https://avd.aquasec.com/nvd/cve-2025-1492 |
|
| Wireshark: Wireshark: Denial of service via IEEE 802.11 | CVE-2026-0959 |
| protocol dissector crash |
| https://avd.aquasec.com/nvd/cve-2026-0959 |
|
| wireshark: IPPUSB dissector crash | CVE-2021-39920 | LOW |
| https://avd.aquasec.com/nvd/cve-2021-39920 |
|
| SPRT dissector crash in Wireshark 4.2.0 to 4.0.5 and 4.0.0 | CVE-2024-8645 |
| to 4.0.15... |
| https://avd.aquasec.com/nvd/cve-2024-8645 |
|
| wireshark-common | CVE-2024-11595 | MEDIUM |
| wireshark: Loop with Unreachable Exit Condition ('Infinite |
| Loop') in Wireshark |
|
var/lib/fwupd/pki/secret.key (secrets)
Total: 1 (UNKNOWN: 0, LOW: 0, MEDIUM: 0, HIGH: 1, CRITICAL: 0)
HIGH: AsymmetricPrivateKey (private-key)
Asymmetric Private Key
var/lib/fwupd/pki/secret.key:2-38 (offset: 32 bytes)
1 -----BEGIN RSA PRIVATE KEY-----
2 *****
3 *****
4 *****
5 *****
6 *****
7 *****
8 *****
9 *****
10 *****
11 *****
12 *****
13 *****
14 *****
15 *****
16 *****
17 *****
18 *****
19 *****
20 *****
21 *****
22 *****
23 *****

```

```

hacker@23520536:~$ trivy rootfs --vuln-type os,library /
2026-05-05T12:59:16Z    WARN    '--vuln-type' is deprecated. Use '--pkg-types' instead.
2026-05-05T12:59:16Z    INFO    [vuln] Vulnerability scanning is enabled
2026-05-05T12:59:16Z    INFO    [secret] Secret scanning is enabled
2026-05-05T12:59:16Z    INFO    [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-05-05T12:59:16Z    INFO    [secret] Please see https://trivy.dev/docs/v0.70/guide/scanner/secret#recommendation for faster secret detection

```

Khi thực hiện quét hệ thống bằng lệnh `trivy rootfs /`, công cụ đã phát hiện một khóa RSA Private Key tại đường dẫn `/var/lib/fwupd/pki/secret.key`. Đây là một phát hiện quan trọng vì Trivy không chỉ quét các phần mềm lỗi thời mà còn có khả năng phát hiện các thông tin nhạy cảm (secrets) bị để lộ trong mã nguồn hoặc hệ thống file.

2.4.3 So sánh Trivy và Nessus

Tiêu chí	Nessus	Trivy
Giá thành	Có bản miễn phí giới hạn	Hoàn toàn miễn phí
Loại quét	Network, system	Chủ yếu system, container
Dễ sử dụng	Rất dễ	Rất dễ
Tốc độ scan	Trung bình	Nhanh
Giao diện	Web GUI	CLI
Tài nguyên	Nặng	Nhẹ

Nhận xét:

Trivy là công cụ nhẹ, dễ sử dụng và phù hợp cho việc kiểm tra nhanh lỗ hổng hệ thống trong môi trường học tập. Tuy không mạnh như Nessus trong việc quét mạng, nhưng Trivy vẫn là lựa chọn tốt cho các bài lab cơ bản.

HẾT